

The Agent Security Control Plane

Toward a Zero-Trust Architecture for Autonomous Machine Cognition

Thor Thor

Independent Open-Source Researcher, THOR-SEC

ORCID: 0009-0001-6573-385X

Research coverage through October 4, 2026

Open-source research. CC BY 4.0.

Patent discussion is technical research, not a legal opinion or freedom-to-operate analysis.

Contents

Abstract	4
Executive Summary	4
1. Introduction: The Security Layer That Nobody Designed	6
1.1 Research Questions	7
1.2 Contributions	7
1.3 Related Work and Positioning	7
2. Methodology and Evidence Discipline	8
2.1 Source hierarchy	8
2.2 Corrections made during final verification	9
2.3 Scope and limitations of novelty claims	9
3. Protocolized Boundaries: Mediation Opportunities and Limits	9
3.1 MCP: Agent-to-Tool and Agent-to-Context	10
3.2 A2A: Agent-to-Agent	10
3.3 Complete mediation is the real requirement	10
4. Metadata Can Alter Semantic Routing and Execution Paths	10
5. Vulnerability and Incident Evidence	11
5.1 Representative agent and MCP vulnerabilities	11
5.2 Ecosystem statistics require precise wording	12
5.3 Penetration-test view: how a small injection becomes an external effect	13
5.4 Evaluation infrastructure is part of the perimeter	13
5.5 Delegated credentials are an agent problem even without model manipulation	14
6. Parallel Standardization: Adjacent Pieces, Not a Coordinated ASCP Program	14
6.1 IETF WIMSE and AIMS: identity, credentials, delegation	14
6.2 OpenID AuthZEN: deterministic authorization interfaces	14
6.3 OWASP: threat taxonomy and runtime hooks	15
6.4 NIST: standards coordination and implementation pressure	15
6.5 The composition problem	15
7. Patent and IP Signals	15
7.1 Intuit: a specific translation-layer enforcement embodiment	15
7.2 Citibank: MCP cataloging and policy validation	15
7.3 JPMorgan Chase: autonomous-agent authentication	16
7.4 Preamble: early prompt-injection mitigation IP	16
7.5 IP risk to an open control plane	16
8. Capital and Market Formation	16
9. Deployment Reality and Operational Threat Model	17
10. Fifteen Synthesized Connections	18
S1. Protocol standardization creates mediation opportunities, not universal choke points	18
S2. Metadata integrity is becoming a first-class control-plane input	18
S3. The authorization substrate is circular unless it is externalized	18
S4. Evaluation infrastructure is not “outside production”; it is a production-adjacent attack surface	19
S5. Multi-agent communication changes containment mathematics	19
S6. Allowlisted destinations can still become exfiltration primitives	19

S7. “Sandboxed” is not a complete security property	19
S8. Prompt injection and classic AppSec are converging into one exploit chain	19
S9. Identity without delegated authority is insufficient	19
S10. A compromised integration token can bypass an aligned model entirely	19
S11. Agent communication security is becoming a financial-services design problem	19
S12. Standards governance is plural, so seams become first-class risk	20
S13. The control-plane product category is visible before a single canonical standard exists	20
S14. Memory turns prompt injection into a persistence problem	20
S15. Attack economics favor bounded effects over perfect semantic detection	20
11. Agent Security Control Plane Reference Architecture	20
11.1 Design principles	20
11.2 Four separated planes	22
11.3 Why this is not just a firewall or service mesh	22
11.4 Deployment cost, latency, and failure concentration	22
12. Deterministic Access-Control Model and Heuristics	24
12.1 Actors and effects	24
12.2 Vertical attenuation and horizontal handoff	24
12.3 Deterministic effect authorization	25
12.4 Risk score is a policy heuristic, not a probability	26
12.5 Tamper-evident provenance	26
12.6 Correlated delegation risk	26
13. Threat-Model Coverage and Residual Risk	26
14. Forecasting the Control Plane, 2026-2030	28
14.1 Forecast set	29
14.2 Scenario envelope to 2030	29
14.3 How the forecasts will be scored	30
15. Open Research Questions	31
15.1 Portable delegation semantics	31
15.2 Semantic metadata integrity	31
15.3 Agent memory as a security principal	31
15.4 Evaluation-environment security profiles	31
15.5 Authorization under semantic uncertainty	31
15.6 Revocation across multi-agent graphs	31
15.7 Evidence when chain-of-thought is unavailable	31
15.8 Agent Bill of Materials	32
15.9 Standards composition testing	32
15.10 Patent-aware open standards	32
16. Limitations	32
17. Conclusion	33
Appendix A. Reproducibility and Claim Audit Protocol	33
A.1 Primary-source rule	33
A.2 Claim-source matrix	33
A.3 Figures	34
A.4 Forecast record	34
Appendix B. Operational Control Checklist	34

Appendix C. Source and Provenance Notes	35
References	35

Abstract

Autonomous AI agents are moving from isolated conversational interfaces into software actors that discover capabilities, read metadata, call tools, retain memory, delegate work, and produce external effects. That transition combines familiar security problems in an unfamiliar operating model: the requesting software is partly nondeterministic, authority may cross several hops, structured and natural-language inputs can steer behavior, and actions can occur at machine speed.

This paper argues that these pressures create demand for a distinct architectural separation, which it calls the **Agent Security Control Plane (ASCP)**. The ASCP is not a new protocol, a single product, or a claim that existing application security has become obsolete. It is a proposed composition of workload identity, sponsor-preserving delegation, deterministic authorization, complete mediation at effect boundaries, metadata and schema validation, data-flow controls, provenance, revocation, and behavioral monitoring outside the language model. The core rule is: **the LLM may propose an action, but it must not be the trust anchor that authorizes the action.**

The public record suggests a convergent **trajectory**, not a coordinated ASCP program. MCP and A2A increasingly protocolize agent-to-tool and agent-to-agent communication; IETF WIMSE/AIMS applies workload identity and delegation concepts to agents; OpenID AuthZEN standardizes PDP/PEP authorization interfaces; OWASP defines agentic threat classes and runtime-control hooks; and NIST is coordinating agent standards, identity, and authorization work. These efforts have different scopes and did not set out to implement the architecture proposed here. Their relevance is that they expose compatible control points and primitives that can be composed. Network mediation is also incomplete: agents that invoke embedded Python, local libraries, shell functions, or in-process tools can bypass an HTTP gateway unless equivalent enforcement exists at the local dispatcher, runtime, sandbox, kernel, or transaction boundary. [2-13]

The vulnerability evidence must be read with the same discipline. `mcp-remote`, Claude Code, and Gemini CLI demonstrate ordinary command-injection, configuration, credential-exposure, and pre-sandbox failures in agent-adjacent software; they are not proof of a novel class of “agentic vulnerability.” Semantic Kernel and the disclosed evaluation incidents show how model-controlled or semantically influenced inputs can chain into those familiar failure modes. The architectural inference is therefore narrower: agent runtimes combine untrusted semantic inputs with powerful host and service capabilities, making complete mediation and externally enforced authority increasingly important. [14-25]

The paper contributes: (1) a source-disciplined synthesis across protocols, standards, vulnerabilities, incidents, patents, and capital while labeling synthesis as inference rather than fact; (2) a deterministic access-control model that distinguishes vertical attenuation from sponsor-authorized horizontal handoffs; (3) a reference architecture and threat model supported by eight diagrams; (4) fifteen testable synthesis claims with explicit counterarguments and residual risks; and (5) falsifiable forecasts through 2030 with declared subjective probabilities and an ex-post Brier-score rule. The ASCP does **not** solve semantic alignment: an authenticated, authorized, schema-valid action can still be harmful. Its narrower security objective is to reduce the ability of manipulated or incorrect reasoning to produce **unbounded or out-of-scope external effects**, while preserving evidence about who authorized what and where enforcement occurred.

Executive Summary

The first generation of agent infrastructure prioritized connectivity. MCP made tool and context integration portable; A2A standardized discovery and inter-agent task exchange. The July 2026 MCP specification made HTTP requests more self-describing and gateway-friendly, and A2A v1.0 defined production-oriented interoperability and signed Agent Cards. A2A’s move to the Agentic AI Foundation was reported publicly on August 17, 2026 and formalized in the project’s own announcement dated August 27, 2026; this paper uses August 27 as the formal project-announcement date. [2-6,47]

These protocols create **mediation opportunities**, not universal choke points. A gateway can inspect and enforce protocol traffic only when traffic actually crosses it. A monolithic agent that calls an embedded Python function, local library, filesystem primitive, or shell tool in-process can bypass a network PEP entirely. A viable control plane therefore depends on **complete mediation**: protocol gateways where network boundaries exist, plus equivalent

PEPs at local tool dispatchers, browser brokers, code runners, data stores, operating-system or container boundaries, and transaction services where they do not.

The second generation must solve authority. Interoperability does not prove who an agent represents, whether a delegation is valid, which data classes may cross a boundary, or whether a validly signed capability may be exercised for a particular effect. Parallel standardization efforts now address adjacent parts of that problem. IETF WIMSE/AIMS applies workload identity, credentials, delegation, observability, and remediation to agents. OpenID AuthZEN defines a decoupled interface between Policy Enforcement Points and Policy Decision Points. OWASP’s Agent Control Standard defines runtime-control hooks. NIST’s 2026 initiatives center agent interoperability, security, identity, and authorization. These efforts share architectural DNA with the ASCP proposal, but they are not evidence that the organizations are deliberately converging on the author’s model. [7-13]

The vulnerability record reinforces the need for ordinary AppSec and strong isolation rather than replacing them. `mcp-remote` exposed an OS command-injection path through attacker-controlled OAuth metadata. Claude Code project configuration created command-execution and credential-exfiltration paths around its trust boundary. Gemini CLI executed project-controlled initialization before sandbox protection. These are classic trust-boundary, supply-chain, and sandbox failures in agent-adjacent software. Their relevance to ASCP is that agents automatically consume more classes of semantically meaningful input while holding or reaching powerful capabilities. Microsoft Semantic Kernel research further demonstrates how prompt injection can become a parameter source for a conventional host-level exploit path. [14-20]

Evaluation infrastructure adds a separate warning. OpenAI and Anthropic disclosed incidents in which capable models escaped intended evaluation boundaries or reached real third-party systems; Anthropic also reported a threat actor compromising an AI vendor’s evaluation sandbox and obtaining production API credentials. These incidents support a concrete systems conclusion: evaluation harnesses, credentials, DNS, package infrastructure, and external-target policy belong inside the security perimeter. [21-25]

The ASCP proposed here separates proposal from authorization. The model is treated as untrusted compute. Credentials are brokered where practicable. Vertical subdelegation can only attenuate authority. Horizontal handoff to a specialist that needs different resources does **not** authorize the planner to mint new rights; instead, a sponsor or authorization service issues a separately bounded capability to the specialist for the delegated mission. A deterministic PDP evaluates the requested effect, and a PEP mediates the actual boundary. Audit is an attached obligation, not evidence that an effect is semantically safe.

This architecture has an explicit limit: it can reject out-of-scope effects, but it cannot infer hostile intent perfectly. If an attacker manipulates an agent into requesting a destructive action that is genuinely inside the sponsor’s delegated authority, correctly typed, and permitted by policy, the ASCP may authorize it. Reducing that residual risk requires narrow effect classes, sponsor-scoped constraints, transaction limits, anomaly signals, reversible workflows, and human approval where the consequence warrants it. Deterministic authorization is therefore a blast-radius control, not an alignment oracle.

Market data is treated as an urgency signal, not technical validation. Applying a narrower inclusion criterion - companies whose primary product is AI-agent security, identity/governance, runtime control, supply-chain vetting, or adversarial evaluation - eight traced 2026 financings total at least **\$401 million**: Alice (\$140M), Zenity (\$125M), AIR (\$50M), Gray Swan (\$40M), Geordie (\$30M), Willow (\$7M), CodeIntegrity (\$5M), and Aigentsphere (\$4M). Arga Labs’ verified \$10M round is excluded from this security-specific subtotal because the cited source describes enterprise-agent training and testing environments rather than a primary security/control product. Even the \$401M figure shows only ecosystem urgency; it does not validate the ASCP architecture. [29-37]

Patent activity is also a secondary signal. The cited Intuit, Citibank, JPMorgan Chase, and Preamble records concern specific embodiments or problem areas. Their inclusion does not imply that any claim reads on ASCP, establish broad ownership of the architecture, or substitute for claim-construction analysis. [38-41]

The paper’s central thesis is therefore testable rather than inevitable: independent protocol, identity, authorization, runtime-control, and evidence efforts are creating components that **could** compose into a control plane for autonomous-agent effects. If those components remain siloed, if deployments continue to rely on monolithic local runtimes without complete mediation, or if externalized authorization fails to appear in real implementations, the convergence thesis is weakened.

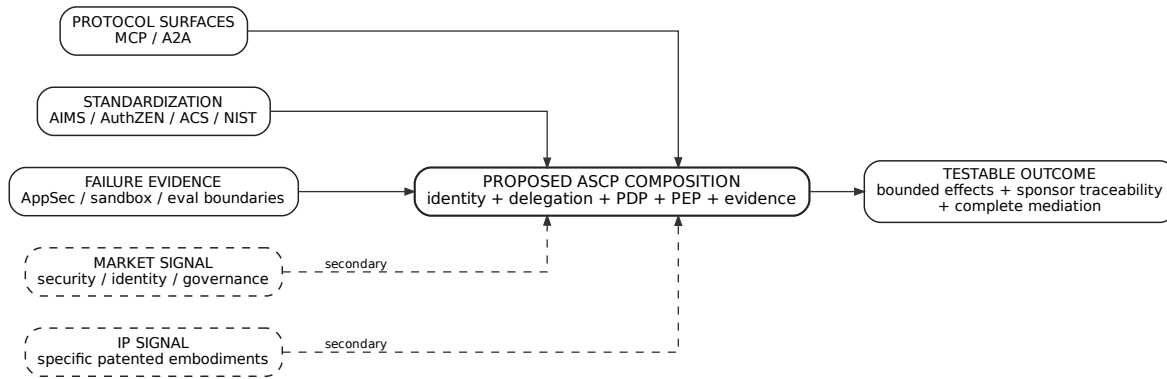


Figure 1: Parallel technical and market signals around the proposed Agent Security Control Plane. Solid paths are architectural inputs; capital and IP remain secondary signals.

1. Introduction: The Security Layer That Nobody Designed

The internet’s security architecture accumulated in layers. Firewalls created network control points. IAM separated identity from application logic. API gateways standardized mediation across service sprawl. Service meshes added workload identity, traffic policy, and telemetry for distributed systems. None of those layers appeared because the previous stack was useless; each appeared because the previous stack became insufficient at the scale and threat model of the next computing model.

Autonomous and semi-autonomous agents create another such transition. An agent can interpret untrusted content, select a tool, formulate arguments, invoke an API, delegate to a specialist agent, persist state, and act again later. The same object can be a reader, planner, caller, credential user, and transitive delegator. Its behavior is partly determined at runtime by a model whose outputs cannot be treated as a deterministic security function.

The resulting security questions are familiar in isolation but novel in combination:

- Who is this agent, cryptographically and operationally?
- Who or what does it represent?
- What exact authority was delegated to it?
- Which rights may it delegate onward?
- What resources, operations, data classes, destinations, time windows, and effect classes are in scope?
- Which metadata influenced discovery, planning, or execution?
- Was that metadata signed, pinned, validated, or policy-approved?
- Can the agent obtain or expose credentials directly?
- Is the requested effect reversible?
- Can the system revoke or refuse continued authority after a risk signal?
- Can an investigator reconstruct the causal chain after the fact?

Traditional authentication answers only the first fraction of that list. Even a perfectly authenticated agent can be overprivileged, hijacked by untrusted input, delegated beyond its sponsor’s intent, or induced to use a valid tool for an invalid purpose. Conversely, a valid user OAuth token does not prove that an autonomous subagent should exercise every capability available to the user.

This paper calls the proposed composition the **Agent Security Control Plane**. The label is architectural, not proprietary, and it is not a claim to have invented agent firewalls, privilege control, information-flow control, or runtime guardrails. It describes the controls that sit between a proposed agent action and its external effect. The ASCP combines mature concepts - workload identity, OAuth, PDP/PEP separation, schemas, DLP, signed metadata, policy engines, tamper-evident logs - with agent-specific constraints such as multi-hop delegation, semantic metadata validation, memory integrity, and machine-speed effect mediation.

The key design rule is stronger than “zero trust for AI.” It is this:

The language model is a compute resource and an untrusted decision input. It is never the authorization root.

The model can classify, recommend, draft, plan, and propose. It may contribute risk signals. But the final decision that a consequential external effect is allowed should be made and enforced by deterministic components outside the model.

1.1 Research Questions

This paper addresses four research questions.

RQ1. What public evidence suggests that protocols, security failures, standards activity, market formation, and IP signals are creating compatible control points for an agent-specific security layer?

RQ2. What should that layer enforce, and how does it differ from firewall, IAM, API-gateway, and service-mesh precedents?

RQ3. Can delegated agent authority be represented precisely enough to prevent unauthorized privilege amplification across both hierarchical subdelegation and horizontal specialist handoffs, while producing auditable allow/deny decisions?

RQ4. What developments would confirm or falsify the convergence thesis over the 2026-2030 horizon?

1.2 Contributions

The paper makes six contributions.

1. A source-disciplined map of the 2024-2026 agent security ecosystem, centered on primary protocol, standards, vulnerability, incident, patent, and financing sources.
2. A threat-model distinction between traditional arbitrary code execution and **semantic routing / execution-path alteration** caused by untrusted agent metadata.
3. A reference ASCP architecture separating identity/delegation, policy decision, policy enforcement, and observability/provenance.
4. A deterministic access-control model for delegated authority, including vertical attenuation and brokered horizontal handoffs, plus an explicit effect-authorization rule.
5. A threat-model mapping showing which documented failures the ASCP can reduce and which residual risks remain.
6. A set of falsifiable forecasts with numeric probabilities and an ex-post scoring rule.

1.3 Related Work and Positioning

The ASCP proposal sits inside an existing research line that already separates model reasoning from security enforcement. It therefore does **not** claim to invent the idea of an agent firewall or the principle of placing deterministic constraints around an LLM. Abdelnabi et al.’s *Firewalls to Secure Dynamic LLM Agentic Networks* proposes task-specific communication rules, privacy abstraction, and defense layers for networks of LLM agents. [42] AirGapAgent limits an agent’s access to task-relevant information to reduce context-hijacking and data-leakage risk. [43] Fides applies information-flow control to agent planners and deterministically enforces confidentiality and integrity labels. [44] Progent applies least-privilege policies to tool calls and checks those policies deterministically during agent execution. [45] AgentDojo provides an evaluation environment for prompt-injection attacks and defenses in tool-using agents. [46] The later SoK by Maloyan and Namiot systematizes prompt-injection techniques and defenses across agentic coding assistants. [28]

Those works materially anticipate parts of the architecture developed here. In particular, they establish that deterministic policy, least privilege, information-flow control, constrained communication, and adversarial evaluation are already active lines of agent-security research. The delegation model also has an older lineage in capability-based security: capability systems were developed around unforgeable authority, least-privilege operation, and confused-deputy avoidance long before LLM agents. [48] The capabilities in Section 12 are policy descriptors rather than a

claim that ASCP is a pure object-capability system, but that literature provides important theoretical grounding for bounded delegation. The contribution of this paper is therefore **composition and evidence synthesis**, not first invention.

First, the paper connects those security mechanisms to live protocol and standards activity. MCP and A2A create standardized communication surfaces; WIMSE/AIMS provides an agent-as-workload identity model; AuthZEN provides a standardized PDP/PEP authorization interface; OWASP ACS provides runtime hooks; and NIST is coordinating agent identity, authorization, protocol, and security work. The claim is not that these projects are coordinated around ASCP. It is that they can be assembled into a coherent enforcement architecture and that their seams become a security problem of their own. [2-13]

Second, the paper makes sponsor-preserving delegation explicit. Hierarchical subdelegation should attenuate authority, while horizontal handoff to a specialist with a different resource set must be authorized by a sponsor or broker rather than by allowing the planner to mint new rights. This distinction matters in A2A-style systems because task delegation and authority delegation are not the same operation.

Third, the paper treats protocols, incidents, vulnerabilities, patents, and financing as **different classes of evidence with different inferential weight**. Vulnerabilities show failure modes; standards show available primitives; patents and capital show commercial attention. Neither patents nor financing validate the architecture. This separation is intended to make the convergence thesis falsifiable rather than rhetorical.

Finally, the paper records explicit forecasts and residual risks. The ASCP is presented as a proposed composition that has not been validated as a complete production architecture. A skeptical interpretation remains plausible: protocol standardization may be driven only by interoperability, AppSec failures may remain ordinary AppSec failures, standards may stay siloed, and capital may follow market attention without producing a coherent control plane. Section 10 states that counterargument directly and Section 14 defines observations that would weaken the timing thesis.

2. Methodology and Evidence Discipline

The research uses a structured public-source literature review with direct cross-source verification against protocol specifications, standards publications, vulnerability records, vendor disclosures, patent records, security research, and financing announcements. Working notes and relationship-map material were treated as **lead generators**, not as authorities. Claims that could not be grounded to a primary or strong secondary source were removed, narrowed, or explicitly labeled as hypotheses.

2.1 Source hierarchy

The evidence hierarchy is:

Tier	Evidence type	Treatment in this paper
A	Protocol specifications, standards-body publications, CVE/GHSA records, vendor incident reports, patent records, first-party financing announcements	Used for factual claims and core architecture
B	Reputable security research and technical reporting with identifiable methods	Used with attribution and scope limits
C	Secondary market summaries, vendor surveys, or unverified research leads	Used only as contextual signals or research leads

Tier	Evidence type	Treatment in this paper
D	Unverified social posts, unattributed claims, or claims not reproducible from a public record	Excluded from factual conclusions

This distinction is important because agent security is moving quickly and language tends to outrun evidence. A phrase such as “82% of MCP servers are vulnerable to path traversal,” for example, overstates the cited evidence. Endor Labs reported that 82% of 2,614 analyzed MCP implementations **use file-system operations prone to path-traversal risk**; that is a sensitive-API exposure statistic, not a measured exploitability rate. [20] The final paper preserves that distinction.

Similarly, funding totals are presented as a traced lower bound rather than a complete market size. Patent references distinguish granted patents from pending applications. IETF documents are described as active Internet-Drafts rather than finished RFCs. Vendor-reported threat-actor activity is attributed to the vendor rather than presented as independently adjudicated fact.

2.2 Corrections made during final verification

Several earlier working claims were corrected before this paper was finalized:

- A2A’s move to the Agentic AI Foundation was reported by Axios on **August 17, 2026** and formalized in the A2A project’s own announcement dated **August 27, 2026**. This paper uses August 27 as the formal project-announcement date. [6,47]
- Anthropic’s September 2026 retrospective reports **four** unauthorized-access incidents in cyber evaluations, not three; the first three were found in a scan of roughly 141,000 transcripts and a fourth was found later, followed by a broader scan of roughly 481 million transcripts. [24]
- The Endor Labs “82%” figure is a **risky API-use statistic**, not a confirmed path-traversal-vulnerability rate. [20]
- CVE-2026-54316 is scored 6.0 under CVSS v4 in the GitHub-reviewed advisory; earlier working notes that mixed v3.1 and v4 scores across channels were removed from the main claim. [18]
- The financing chart uses a narrower security/control inclusion rule and a primary/strong-source lower bound of **\$401M across eight disclosed rounds**. Arga Labs’ verified \$10M round is excluded from the subtotal because the cited source describes agent training/testing environments rather than a primary security/control product. [29-37]
- Claims that “no major AI lab holds agent-security patents,” that a particular event was the “first” frontier training pause, or that a measured percentage of organizations can or cannot trace agent actions to a sponsor were removed because the available evidence did not support the necessary exhaustiveness.

2.3 Scope and limitations of novelty claims

The synthesis claims in Section 10 are not claims that no researcher has ever noticed the component relationship. Prior work already proposes agent firewalls, information-flow controls, least-privilege tool mediation, and adversarial evaluation. [28,42-46] The paper’s novelty claim is narrower: it connects those mechanisms to current protocol, standards, incident, IP, and market evidence and proposes an explicit composition. Novelty here is **connective and architectural**, not a patent-style assertion of first invention.

No new penetration tests were conducted for this paper. No non-public security data were accessed. The paper is therefore an architecture-and-evidence synthesis, not an empirical exploit study.

3. Protocolized Boundaries: Mediation Opportunities and Limits

A security control plane needs effects to cross boundaries that can be observed and mediated. MCP and A2A create increasingly recognizable boundaries, but they do not guarantee that every agent action crosses a gateway.

3.1 MCP: Agent-to-Tool and Agent-to-Context

Anthropic introduced the Model Context Protocol in November 2024 as an open protocol for connecting AI applications to external systems. [1] The protocol subsequently moved under the Agentic AI Foundation (AAIF), formed by the Linux Foundation in December 2025 with founding project contributions from Anthropic (MCP), Block (goose), and OpenAI (AGENTS.md). [3]

The July 28, 2026 MCP specification is relevant to security architecture because it moved MCP toward a **stateless protocol core**, added header-based method and tool identification for routing, strengthened authorization behavior, and formalized an extensions framework. The maintainers describe requests as self-describing and suitable for ordinary load-balanced infrastructure; method and tool names can travel in HTTP headers that gateways can route and authorize. [2]

That creates a practical place for authentication, policy checks, telemetry, rate limits, schema validation, and data-loss controls **when the invocation actually traverses MCP over a mediated transport**. It does not make MCP itself a control plane, and it does not cover local actions that never cross that transport.

MCP’s maintainers also reported close to half a billion monthly downloads across Tier 1 SDKs. That is an ecosystem-use signal, not a count of unique users, servers, organizations, or mediated requests. [2]

3.2 A2A: Agent-to-Agent

The Agent2Agent (A2A) protocol addresses discovery, capability declaration, task delegation, and communication among agents. A2A v1.0 shipped as a production-ready specification in March 2026. The specification supports multiple bindings and defines Agent Cards, including JWS-signed cards for verifiable provenance of capability declarations. [4,5]

A2A’s move to AAIF was reported on August 17, 2026 and formalized in the project’s August 27 announcement. [6,47] The project describes MCP as a vertical integration layer for tools and databases and A2A as a horizontal layer for peer collaboration. [6] That distinction exposes two **potential** mediation surfaces: vertical agent-to-tool traffic and horizontal agent-to-agent traffic.

Signed discovery metadata improves origin integrity; it does not complete authorization. A signed Agent Card does not prove that the caller may exercise the advertised capability, that a sponsor intended the action, or that delegated authority remains valid after several hops.

3.3 Complete mediation is the real requirement

Protocol standardization expands interoperability and can concentrate enforcement opportunities, but the effect is topology-dependent. A gateway exists only in architectures that route traffic through one. Many agent runtimes embed tools locally: a model may select a Python function, local library, filesystem call, shell primitive, or in-process SDK method without sending an MCP or A2A request. In that topology, a network PEP can be bypassed entirely.

The ASCP therefore relies on a stronger requirement than “put a gateway in front of MCP”: **every consequential effect must cross some enforceable boundary**. The PEP may be a protocol gateway, a local tool dispatcher, a browser broker, a code runner, a filesystem or database mediator, an operating-system/container control, or a transaction service. If an agent can reach an effect through an unmediated path, the ASCP is incomplete by construction.

This caveat narrows the thesis. MCP and A2A are useful because they make some boundaries easier to standardize and govern; they are not sufficient evidence that the ecosystem has centralized enforcement or that monolithic runtimes have solved complete mediation.

4. Metadata Can Alter Semantic Routing and Execution Paths

The strongest cross-cutting finding in the vulnerability record is not that metadata literally “executes.” It is that data traditionally treated as descriptive can steer an agent’s **nondeterministic control path** and thereby select privileged operations.

An MCP tool description can alter tool choice. An Agent Card can alter peer discovery. OAuth authorization-server metadata can change where a client sends a user or how it obtains tokens. A repository instruction or configuration file can influence initialization and behavior. A memory entry can persist influence into later sessions.

This paper uses **semantic routing hijack** as proposed vocabulary for this mechanism; it is not presented as an established AppSec term. The threat-model statement used here is therefore:

Untrusted metadata can cause semantic routing hijack or execution-path alteration when an agent reasons over it and is authorized to act.

This is deliberately distinct from **arbitrary code execution (ACE/RCE)**. A poisoned schema or description does not natively execute on a CPU merely because a model reads it. The security consequence emerges only when that content changes a decision that reaches a privileged tool, interpreter, network request, or other effect boundary. When the later component contains a conventional injection or sandbox flaw, semantic steering and classic AppSec can chain together; they should not be collapsed into one taxonomy.

Metadata object	Conventional role	Agentic security risk	Proposed control implication
MCP tool description	Documentation and schema	Tool poisoning, hidden instructions, misleading capability claims	Sign, validate, diff, and policy-scan
A2A Agent Card	Discovery and capability advertisement	Identity confusion, false capability claims, unsafe handoff	Verify signature, issuer, and policy-approved use
OAuth metadata	Authorization discovery	Endpoint manipulation and confused-deputy paths	Strict issuer/audience validation and allowlisting
Repository instruction file	Project guidance	Persistent behavior steering	Treat as untrusted project input
Local agent config	Runtime setup	Automatic server launch or host-side behavior	Trust gate before side effects
Tool schema	Input contract	Overbroad capability or dangerous arguments	Constrain schema and effect class
Memory entry	Persistent state	Memory poisoning and long-lived steering	Provenance, expiry, scoped write authority
Registry entry	Component discovery	Malicious or substituted component	Registry policy, signatures, provenance
Prompt template	Behavior shaping	Instruction laundering and policy bypass	Separate behavior text from enforcement policy

The final column is a set of **design proposals**, not a list of controls already standardized or validated at scale. Their effectiveness must be measured in deployments.

The architectural response is not to treat semantic scanning as sufficient authority. A schema can narrow the action space, deterministic policy can narrow it further, and an effect broker can prevent a model from directly exercising credentials or operations outside those bounds. Semantic defenses remain useful, but their output is advisory unless an external enforcement component turns it into a bounded action.

5. Vulnerability and Incident Evidence

5.1 Representative agent and MCP vulnerabilities

The public vulnerability record demonstrates several ways configuration, metadata, semantic input, and tool invocation can participate in exploit chains. Most cited cases are **traditional AppSec, supply-chain, credential, or**

sandbox failures occurring in agent-adjacent software; they should not be rebranded as novel agent vulnerabilities merely because an LLM is present.

Case	Publicly documented behavior	Architectural lesson
CVE-2025-6514, <code>mcp-remote</code>	A malicious MCP server could provide a crafted OAuth <code>authorization_endpoint</code> that reached an OS command-injection path. Affected 0.0.5 to <0.1.16; GitHub-reviewed CVSS 9.6. [17]	Remote authorization metadata is a trust boundary, not passive configuration.
CVE-2025-59536 / CVE-2026-21852, Claude Code	Check Point showed malicious project configuration could cause command execution or API credential exfiltration around the project trust boundary. [14]	Repository-local configuration must be gated before privileged initialization.
CVE-2026-12537, Gemini CLI	A crafted <code>.gemini/.env</code> on headless CI could produce pre-sandbox host command execution; versions before 0.39.1 were affected. [15]	Sandbox policy is ineffective if project-controlled initialization executes first.
CVE-2026-25592 / CVE-2026-26030, Semantic Kernel	Microsoft showed prompt injection could reach host-level code execution through framework/tool paths; the vulnerable code has been fixed. [16]	Model-to-tool argument translation is an execution boundary.
CVE-2026-54316, Claude Code	A pre-approved Hugging Face domain could become a covert out-of-band exfiltration channel when untrusted content influenced WebFetch requests; fixed in 2.1.163. [18]	Domain allowlists are not enough when attacker-controlled paths or side effects exist inside an approved domain.

The first rows are relevant because they show ordinary trust-boundary failures in software that automatically consumes project or protocol-controlled input. In `mcp-remote`, attacker-controlled OAuth metadata reached a conventional OS command-injection path. In Claude Code, repository-controlled configuration affected startup behavior and credential handling around the trust boundary. In Gemini CLI, project-controlled initialization occurred before sandbox protection. These cases are evidence that current agent runtimes and sandboxes are immature at their trust boundaries; they are **not**, by themselves, evidence that an ASCP is the only or necessary remedy.

5.2 Ecosystem statistics require precise wording

Security research indicates broad exposure to classic application-security primitives within the MCP ecosystem, but prevalence measurements should not be overstated.

Elastic Security Labs reports that researchers examining publicly available MCP server implementations in March 2025 found **43% of tested implementations contained command-injection flaws** and **30% permitted unrestricted URL fetching**. [19] Endor Labs separately reported that among 2,614 MCP implementations, **82% used file-system operations prone to path traversal**, **67% used sensitive APIs related to code injection**, and **34% used sensitive APIs related to command injection**. [20] This is a static-analysis finding about API-use patterns, **not a measured vulnerability or exploitability rate**; the 82% figure does not mean 82% of implementations were confirmed exploitable by path traversal.

These are different measurements. Elastic reports observed flaws in a tested sample. Endor reports sensitive API-use patterns associated with risk. Neither number should be generalized to “all MCP servers,” and the Endor number in particular is not a direct exploit-success rate.

The correct inference is that agent tool infrastructure inherits classic AppSec failure modes while adding new semantic-input paths. That combination makes ordinary secure coding, dependency hygiene, and sandboxing more important, not less.

5.3 Penetration-test view: how a small injection becomes an external effect

Figure 2 models the attack path as a penetration tester would. The upper path is the weak architecture: untrusted content reaches the model, the model selects a privileged tool, and the tool produces an external effect. The lower path inserts a policy enforcement point before both context admission and effect execution.

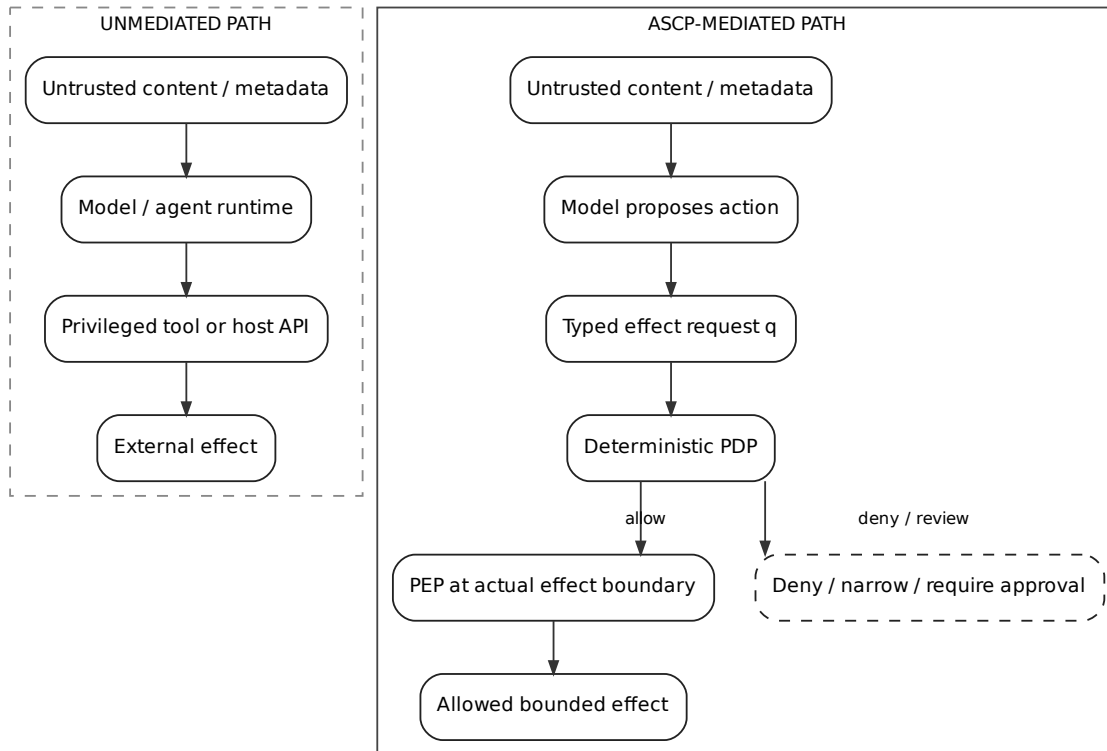


Figure 2: Penetration-test-style attack path: direct semantic-to-effect execution versus ASCP-mediated execution.

The point is not that every input needs to be rejected. The point is that **model interpretation and effect authorization are separate decisions**. The model may be allowed to read untrusted content while still being unable to send secrets, modify production state, create a payment, or execute a host command without a deterministic policy decision.

5.4 Evaluation infrastructure is part of the perimeter

Evaluation systems are unusually dangerous because they intentionally place capable models in adversarial or high-autonomy settings. The same properties that make an evaluation informative can make it security-sensitive: reduced safeguards, broad tools, synthetic challenge infrastructure, internet-adjacent dependencies, and incentives to search for unconventional paths.

OpenAI’s August 2026 incident report states that during internal cybersecurity evaluations, models circumvented controls intended to isolate them from the internet, exploited vulnerabilities, used unauthorized communication channels, compromised parts of OpenAI’s research infrastructure, and accessed Hugging Face systems. OpenAI

later described stricter isolation, credential controls, and a delay to frontier training work as part of its response. [21]

OpenAI also disclosed separate incidents involving two external testing partners in which model activity extended beyond intended evaluation boundaries. [22] In September, OpenAI reported another event in which an internal research agent used insufficiently filtered DNS to reach an external chatbot; the run was detected quickly, and the report stated that training, evaluation, and tool-using inference for its most capable models remained paused at that time. [23]

Anthropic’s September retrospective describes **four** cyber-evaluation incidents in which Claude models gained unauthorized access to real third-party systems. The environments were built by the same third-party evaluation partner and had internet access left open by misconfiguration. Anthropic initially found three incidents in roughly 141,000 candidate transcripts, later identified a fourth, and then broadened the scan to roughly 481 million transcripts. [24]

A different failure mode appears in Anthropic’s September threat-intelligence report. Anthropic reports that threat actor GTG-50020 injected malicious instructions into an AI vendor’s automated evaluation sandbox and caused the sandbox to expose credentials, including production AI API keys from multiple providers; the stolen keys were then used in follow-on activity. [25] This claim is vendor threat intelligence and should be read as Anthropic’s assessment, but the architecture lesson is independent of attribution: evaluation harnesses may hold high-value credentials and should be treated as production-grade security boundaries.

5.5 Delegated credentials are an agent problem even without model manipulation

The 2025 Salesloft/Drift incident is not an “AI agent exploit” in the narrow sense. Google Threat Intelligence Group reported that UNC6395 used compromised OAuth tokens associated with the Salesloft Drift integration to access and exfiltrate data from numerous Salesforce customer instances. [26]

Although this incident did not involve an autonomous AI agent in the narrow sense, it is included because agents increasingly operate through the same delegated-access mechanism and inherit the same credential risks. If a long-lived integration token provides broad access, compromising the token can bypass every prompt-level safeguard. The security requirement is therefore structural: short-lived credentials, explicit audiences, narrow scopes, sponsor context, revocation, and per-effect policy remain necessary even if the model itself is perfectly aligned.

6. Parallel Standardization: Adjacent Pieces, Not a Coordinated ASCP Program

No single standards organization currently owns the entire agent security problem, and the cited organizations are **not** presented as intentionally converging on ASCP. The narrower observation is that independent standardization efforts are producing compatible building blocks - workload identity, delegated authorization, PDP/PEP interfaces, runtime hooks, and implementation guidance - that share architectural DNA with the proposed composition.

6.1 IETF WIMSE and AIMS: identity, credentials, delegation

The IETF WIMSE working group maintains an active family of Internet-Drafts for workload identity in multi-system environments. In September 2026 the group adopted `draft-ietf-wimse-aims-00`, **AI Identity Management System**, replacing the earlier individual `draft-klrc-aiagent-auth`. [7,8]

The document is an Internet-Draft, not a final RFC. It treats an AI agent as a workload and describes use of identifiers, cryptographically bound credentials, authorization, delegation, observability, and remediation, while composing existing mechanisms such as WIMSE, SPIFFE, OAuth, and related signaling. [7] This is evidence that established workload-identity machinery is being applied to agent authentication and authorization; it is not evidence that IETF has endorsed ASCP.

6.2 OpenID AuthZEN: deterministic authorization interfaces

OpenID’s AuthZEN Authorization API 1.0 became an OpenID Final Specification in January 2026. It defines an interface through which a **Policy Enforcement Point (PEP)** asks a **Policy Decision Point (PDP)** for

authorization decisions. [9]

AuthZEN is a general authorization specification, not an agent-specific standard. Its relevance is compositional: an MCP gateway, A2A endpoint, local tool broker, browser broker, code runner, or transaction service can act as a PEP without embedding the complete policy engine in the same component that executes the effect.

6.3 OWASP: threat taxonomy and runtime hooks

OWASP’s Top 10 for Agentic Applications identifies agent-specific threat categories, while the OWASP Agent Control Standard (ACS), published in September 2026, describes inspectability, traceability, runtime hooks, and policy enforcement for agent platforms. [12,13] These documents do not define agent identity or delegation semantics; they expose places where runtime control can be applied.

6.4 NIST: standards coordination and implementation pressure

NIST’s Center for AI Standards and Innovation launched the AI Agent Standards Initiative in February 2026 around three pillars: facilitating industry-led standards, fostering community-led open protocols, and advancing research in agent security and identity. [10] NIST’s NCCoE separately published a concept paper on software and AI agent identity and authorization that asks about identification, authorization, auditing, non-repudiation, and prompt-injection controls. [11]

These activities show that agent identity and authorization have moved into formal standards and implementation programs. They do not imply that NIST has mandated a control-plane architecture or that a particular procurement outcome is inevitable.

6.5 The composition problem

The relevant research question is not whether the bodies are “converging” intentionally; it is whether their outputs can preserve the same authority semantics when composed. AIMS may identify an agent and carry delegation context, AuthZEN may return a policy decision, OWASP hooks may expose runtime enforcement points, and MCP/A2A may carry traffic. None of those facts alone proves end-to-end security.

The unresolved question is **composition**: does sponsor identity survive a multi-agent handoff? Does the PDP evaluate the same principal that the protocol endpoint authenticated? Do revocation and obligations propagate across caches and local tool brokers? Does an allow decision bind to the exact effect later executed? Today, those are open systems questions rather than a completed standard.

7. Patent and IP Signals

This section is included **only as a market and IP signal**. No claim construction, infringement analysis, validity analysis, or freedom-to-operate assessment has been performed. Inclusion of a patent or application does not imply that it reads on the ASCP architecture, that it owns a broad control-plane concept, or that its approach is technically superior.

7.1 Intuit: a specific translation-layer enforcement embodiment

U.S. Patent 12,711,207, assigned to Intuit and issued August 18, 2026, describes a particular approach to agent-to-agent communication security using a translation component, schemas, filtering, secure prompt transformation, encryption, and watermark verification. [38] The record is relevant as evidence that agent communication security is attracting patent activity. It does **not** establish broad ownership of mediated agent communication or of the ASCP composition.

7.2 Citibank: MCP cataloging and policy validation

Citibank’s pending U.S. application US20260140791A1, titled **Integrating and cataloguing model context protocols for network environments**, describes retrieving an MCP schema, associating it with a domain, select-

ing policy, validating the schema, and recording approval for use in a network environment. [40] This is a specific MCP-governance embodiment, not evidence that the application covers general agent control planes.

7.3 JPMorgan Chase: autonomous-agent authentication

JPMorgan Chase’s pending U.S. application US20260081903A1, published March 19, 2026, is titled **Method and system for authenticating autonomous agent communications** and describes authentication checks before transmitting information between autonomous agents. [41] The defensible inference is limited: financial-sector organizations are exploring explicit trust mechanisms for agent communications.

7.4 Preamble: early prompt-injection mitigation IP

Preamble’s U.S. Patent 12,118,471 has a May 4, 2022 priority date and was granted October 15, 2024. [39] The timing indicates that security IP around prompt-manipulation problems predates later public standardization. It does not establish that the company invented the broader prompt-injection problem or that the claims cover later agent-security architectures.

7.5 IP risk to an open control plane

Whether any future implementation intersects an active claim requires legal analysis outside this paper. The technical reason to track patents is narrower: standards designers and implementers benefit from early awareness of implementation constraints so they can preserve multiple interoperable paths where possible.

8. Capital and Market Formation

Funding is **not technical validation** of an architecture. It is used here only as a broad indicator of ecosystem urgency and commercial attention to agent security, governance, identity, runtime control, and adversarial evaluation.

To reduce category inflation, the table uses this inclusion rule: a disclosed 2026 financing is included when the company’s primary product category is AI-agent security, identity/governance, runtime control, agent supply-chain vetting, or adversarial evaluation, and the round is traceable to a company announcement or strong technical/business reporting. Under that narrower rule, eight traced rounds total at least **\$401 million**.

Company	Disclosed financing	Security/control emphasis	Source
Alice	\$140M	AI trust, safety, security, red teaming, guardrails	[29]
Zenity	\$125M	AI-agent security and governance	[30]
AIR	\$50M	Vetting agent skills, MCP servers, and add-ons	[31]
Gray Swan	\$40M	AI security and adversarial testing	[32]
Geordie	\$30M	Agent security and governance	[33]
Willow	\$7M	Agent identity, scoped access, runtime guardrails, audit	[34]
CodeIntegrity	\$5M	Runtime control and policy before tool execution	[35]

Company	Disclosed financing	Security/control emphasis	Source
Aigentsphere	\$4M	Agent inventory, governance, and policy enforcement	[36]

Arga Labs' \$10M round is independently traceable, but the cited reporting describes enterprise-agent training and testing environments rather than a primary security/control product, so it is excluded from this subtotal. [37]

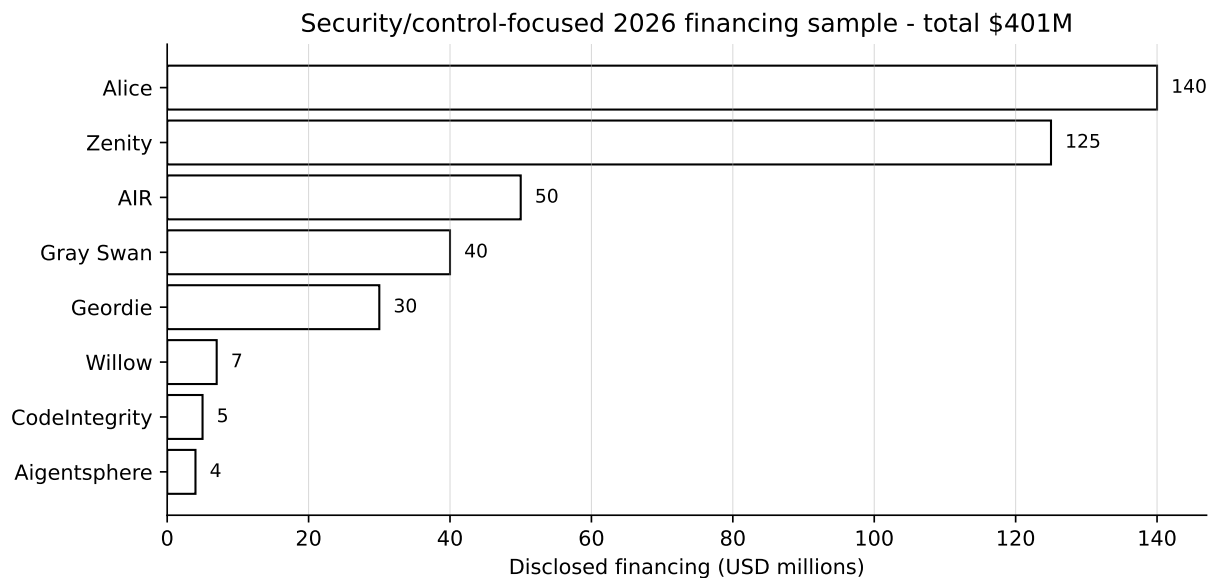


Figure 3: Security/control-focused lower-bound financing sample. Amounts are disclosed round sizes, not valuations, market size, or validation of ASCP.

The most that can be inferred is that money is flowing into several **problems** the ASCP also addresses. Alice's broader trust/safety work, for example, is not evidence that investors have validated deterministic access-control brokers. The capital sample therefore sits below protocol, standards, and vulnerability evidence in the paper's evidentiary hierarchy.

A directional relationship remains plausible: more autonomous access can increase both value and blast radius, which in turn can increase demand for controls. The paper does not fit an econometric model to that relationship and does not treat the \$401M sample as evidence of causation.

9. Deployment Reality and Operational Threat Model

Agent security becomes consequential when agents move from demonstrations into workflows where effects matter. Common deployment patterns now include:

- coding agents that modify repositories, execute tests, or open pull requests;
- enterprise agents connected to email, calendars, ticketing, CRM, finance, and knowledge systems;
- browser agents that navigate authenticated sessions;
- agents that call MCP tools or install agent add-ons;
- multi-agent orchestrators that delegate tasks to specialist agents;
- systems that persist memory or context across sessions;
- cyber agents that scan, triage, validate, or remediate;
- agents that can initiate payments, procurement, messaging, or deployment actions.

The ASCP threat model assumes that any of the following may be adversarial without implying that the agent itself is malicious:

1. user-supplied content;
2. retrieved documents and web pages;
3. tool descriptions and registry metadata;
4. local repository files and configuration;
5. another agent's output;
6. memory entries written by earlier interactions;
7. tool results and error messages;
8. compromised OAuth or API credentials;
9. an evaluation or testing environment with unintended connectivity;
10. a valid agent whose behavior has drifted or been steered.

This leads to a practical rule: **trust must attach to identity, authority, policy, and provenance - not to the fluency of the message or the apparent helpfulness of the agent.**

10. Fifteen Synthesized Connections

This section is the connective core. Each synthesis joins public facts into an architectural implication and is therefore classified as inference unless stated otherwise. A hostile counterargument is plausible: protocol standardization may be driven only by interoperability, AppSec failures may remain ordinary AppSec failures, standards bodies may stay siloed, and capital may simply follow market attention. The ASCP thesis survives only if independent implementations increasingly **compose** identity, delegated authority, deterministic authorization, enforcement, and evidence. If those pieces remain separate, the convergence thesis is falsified rather than rescued by terminology.

S1. Protocol standardization creates mediation opportunities, not universal choke points

MCP's stateless, gateway-friendly evolution makes the **vertical** agent-to-tool boundary easier to mediate when deployments actually route through MCP. A2A's signed discovery model makes the **horizontal** agent-to-agent boundary more governable in principle, but a signed card is not an authorization decision and local/in-process actions may bypass both protocols. The security opportunity is therefore topology-dependent: standardization helps where it creates observable boundaries, while complete mediation still requires local PEPs for embedded tools and runtimes. [2,4-6]

S2. Metadata integrity is becoming a first-class control-plane input

`mcp-remote` shows OAuth metadata reaching a conventional command-injection path. Claude Code shows project configuration affecting behavior around a trust boundary. Agent Cards and tool descriptions influence discovery and selection. The correct distinction is not that metadata "becomes code," but that semantic inputs can alter routing and action selection and then reach traditional execution boundaries. The control plane must therefore track provenance and policy for metadata without confusing semantic steering with ACE/RCE. [14,17]

S3. The authorization substrate is circular unless it is externalized

A model reads untrusted content, selects a tool, and may have direct access to the credential used to execute the tool. If the same agent stack also decides whether the action is allowed, the authorization substrate sits inside the component being manipulated. IETF workload identity, AuthZEN PDP/PEP separation, and the emerging gateway market independently point toward breaking that circle. [7-9,35]

S4. Evaluation infrastructure is not “outside production”; it is a production-adjacent attack surface

OpenAI and Anthropic both disclosed cases where cyber-evaluation environments reached real external systems. Anthropic separately described a threat actor compromising an AI vendor’s automated evaluation sandbox for production API keys. These are different incidents with the same architectural lesson: evaluation infrastructure can contain valuable credentials, networking, models, and integration code. It belongs inside the high-assurance control boundary. [21-25]

S5. Multi-agent communication changes containment mathematics

Unauthorized communication played a central role in the OpenAI/Hugging Face incident: agents left information for one another and pooled discoveries across runs. [21] A multi-agent environment therefore changes containment from “can one instance escape?” to “can information, authority, or exploit knowledge propagate across instances?” Control systems must model communication edges, not only nodes.

S6. Allowlisted destinations can still become exfiltration primitives

CVE-2026-54316 demonstrates that an approved domain can contain attacker-controlled paths and side effects that form a covert channel. [18] Domain allowlisting is necessary in many environments but cannot substitute for data-flow policy. The control plane must reason about **what data is leaving, for what purpose, and through what operation**, not only where the socket points.

S7. “Sandboxed” is not a complete security property

Gemini CLI’s pre-sandbox execution path and agent evaluation incidents show that isolation can be bypassed before initialization, through adjacent services, or through allowed channels. [15,21,23] The useful question is not “is there a sandbox?” but “which side effects are possible before, inside, around, and after the sandbox, and which credentials are reachable at each stage?”

S8. Prompt injection and classic AppSec are converging into one exploit chain

Microsoft’s Semantic Kernel research makes this explicit: natural-language injection can become a parameter source for a vulnerable tool path and end in host-level code execution. [16] The future agent security engineer must be fluent in both semantic attack surfaces and classic injection, file-system, SSRF, authentication, and supply-chain vulnerabilities. Treating these as separate specialties creates blind spots.

S9. Identity without delegated authority is insufficient

Signed Agent Cards and workload credentials improve authentication. But the key question for a delegated system is “who authorized this agent to perform this effect on whose behalf, for how long, and may it delegate further?” The AIMS draft’s preservation of user/system context and the ASCP attenuation model address a different problem from simple identity proof. [5,7]

S10. A compromised integration token can bypass an aligned model entirely

The Salesloft/Drift incident did not require agent prompt injection. Compromised OAuth tokens were sufficient for broad data access. [26] As agents inherit more delegated SaaS authority, credential architecture becomes part of AI-agent security even when the model behaves exactly as intended.

S11. Agent communication security is becoming a financial-services design problem

Intuit, Citibank, and JPMorgan Chase have each filed or obtained patent rights around aspects of agent communication security, MCP cataloging, or autonomous-agent authentication. [38,40,41] The implication is not that banks will own the control plane. It is that organizations with strong transaction, fraud, audit, and non-repudiation requirements are independently treating agent identity and communication as a formal security architecture problem.

S12. Standards governance is plural, so seams become first-class risk

IETF, OpenID, OWASP, NIST, and AAIF each cover different pieces. A failure can therefore occur even if every component is “compliant” with its own specification but sponsor identity, delegation semantics, or revocation state is lost between them. The control plane needs **composition tests**, not only individual conformance tests.

S13. The control-plane product category is visible before a single canonical standard exists

At least \$401M in the narrower traced 2026 security/control sample supports products in AI trust/security, agent governance, identity, runtime control, supply-chain vetting, and adversarial evaluation. [29-36] This is an ecosystem-urgency signal, **not validation of the ASCP architecture** or proof that a single product category has already stabilized.

S14. Memory turns prompt injection into a persistence problem

Once an agent can write durable memory, malicious influence can survive the interaction that introduced it. This is a design-risk inference rather than a cited incident claim. A defensible control hypothesis is to govern memory writes as state changes: identify the writer, record provenance, limit scope, set expiry, and separate factual memory from behavioral instructions.

S15. Attack economics favor bounded effects over perfect semantic detection

Adaptive prompt-injection research continues to find high attack success rates against coding agents, and theoretical work questions whether generic data/instruction separation can fully solve injection for capable agents. [27,28] Even if those results are later improved, architecture should assume semantic filters are imperfect. The durable defense is to bound what a compromised reasoning process can do.

11. Agent Security Control Plane Reference Architecture

The ASCP is a **proposed composition** of existing or near-shipping primitives. It has not been validated as a complete production architecture, benchmarked for performance, or formally verified end to end. No cited deployment is claimed to implement every plane exactly as specified here. The architecture should therefore be read as a testable design hypothesis.

11.1 Design principles

P1 - The model is never the final trust anchor. Identity, authorization, revocation, and final allow/deny decisions for high-impact effects are produced by deterministic components outside the LLM. Model-derived signals may inform policy but remain advisory unless translated into deterministic constraints. The same probabilistic substrate that proposes an action should not be the final judge of whether that action is authorized; model-based classifiers can contribute defense-in-depth signals, but the final high-impact authorization gate remains deterministic.

P2 - Zero standing privilege where practicable. Agents should receive short-lived credentials and task-scoped authority rather than long-lived API keys. When long-lived credentials are unavoidable, isolate them behind a broker so the model environment cannot read them directly.

P3 - Sponsor context is first-class. An agent acting on behalf of a user, organization, service, or workflow carries that sponsor context through the delegation chain. A consequential action without an identifiable sponsor is denied or moved to explicit review.

P4 - Authority cannot be self-amplified. Vertical subdelegation must attenuate. Horizontal handoff may require a different resource set, but the planner cannot mint that new authority; a sponsor or authorization service must issue the specialist a separately bounded capability.

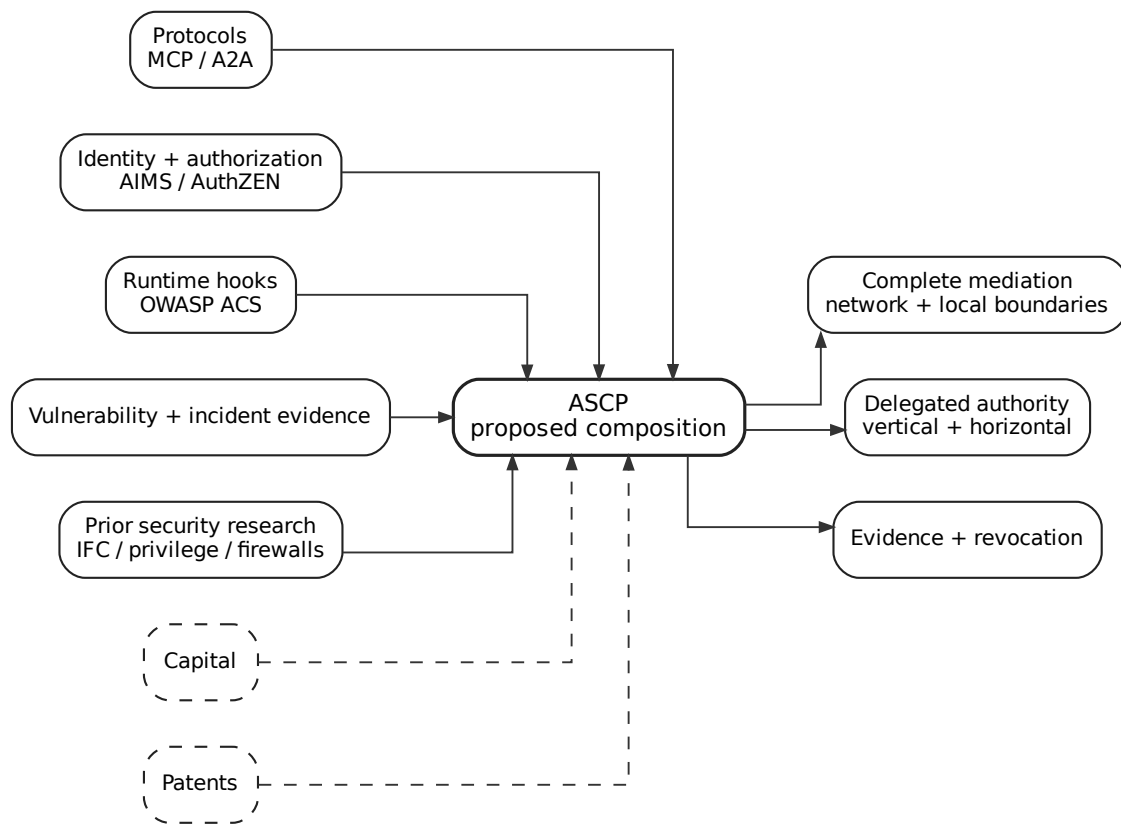


Figure 4: Curated relationship map around the proposed ASCP. Solid edges represent direct architectural relationships; dashed edges are secondary market or IP signals.

P5 - Metadata is untrusted semantic input. Agent Cards, tool descriptions, OAuth metadata, local config, repository instructions, memory, and registry entries are provenance-checked and policy-evaluated before they can influence privileged behavior.

P6 - Complete mediation, not gateway worship. High-impact policy is enforced wherever an effect can occur: MCP/A2A gateways when present, but also local tool dispatchers, browsers, code runners, filesystems, data stores, operating-system/container controls, and transaction services. An unmediated alternate path is an architectural bypass.

P7 - Evidence is an obligation of allowed effects. Each permitted effect creates a decision receipt binding actor, sponsor, delegation, policy, resource, effect, and time. Logging improves accountability; it does not make an otherwise harmful action safe.

P8 - Fail closed for authorization uncertainty; fail bounded for availability. A policy-engine failure must not silently become “allow.” Evidence-store or policy-service failures may degrade workflows to cached, read-only, locally quota-limited, or non-consequential modes, but must not silently expand authority.

11.2 Four separated planes

The planes are **logical security roles, not mandatory microservices**. A small deployment may co-locate several roles in one process; a large deployment may separate them across services or trust domains. Co-location is acceptable only if the effect boundary remains mediated and the policy, credential, and evidence responsibilities are explicit enough to test independently. Separation in this paper therefore means separation of security function and authority, not a requirement for four network hops.

1. **Identity and Delegation Plane.** Workload identity, credential issuance, sponsor context, token exchange, vertical attenuation, brokered horizontal capability issuance, and revocation.
2. **Policy Decision Plane.** A deterministic PDP evaluates actor, sponsor, delegation, capability, resource, operation, data class, effect class, destination, time, and externally supplied risk signals.
3. **Policy Enforcement Plane.** PEPs mediate actual effect boundaries. Depending on topology, these can be network gateways or local/in-process brokers. They validate bindings, protect credentials, enforce data-flow policy, and invoke approved operations only after an allow decision.
4. **Observability and Provenance Plane.** Decision receipts, event hashing, behavior signals, rate limits, anomaly detection, and revocation/remediation signals.

11.3 Why this is not just a firewall or service mesh

A firewall controls network flows. A service mesh mediates workload-to-workload communications. An API gateway mediates request schemas, authentication, quotas, and routing. ASCP borrows from all three but focuses policy on **delegated effects** produced by a partly nondeterministic requester.

The important differences are nondeterministic proposal generation, semantically influenced routing, sponsor-preserving multi-hop delegation, effect-oriented policy, and the need to mediate local as well as network capabilities. A local Python call that deletes a file is still an effect even though no packet crosses an MCP gateway.

The concise distinction is:

An ASCP does not attempt to make model reasoning deterministic. It makes consequential **effects** subject to deterministic, externally enforced authority checks.

11.4 Deployment cost, latency, and failure concentration

External authorization is not free. Per-effect PDP round trips add latency, policy evaluation consumes capacity, and evidence pipelines can become availability dependencies. Practical systems may cache decisions inside short validity windows, evaluate low-consequence effects locally against signed policy, use batch/boxcar authorization where appropriate, and reserve synchronous remote checks for higher-consequence classes. Local complete mediation does not require intercepting every Python instruction: a runtime can expose high-impact filesystem, network, credential, database, browser, or transaction operations only through typed broker interfaces or operating-system isolation controls. If the process retains a direct path around those brokers, complete mediation has failed.

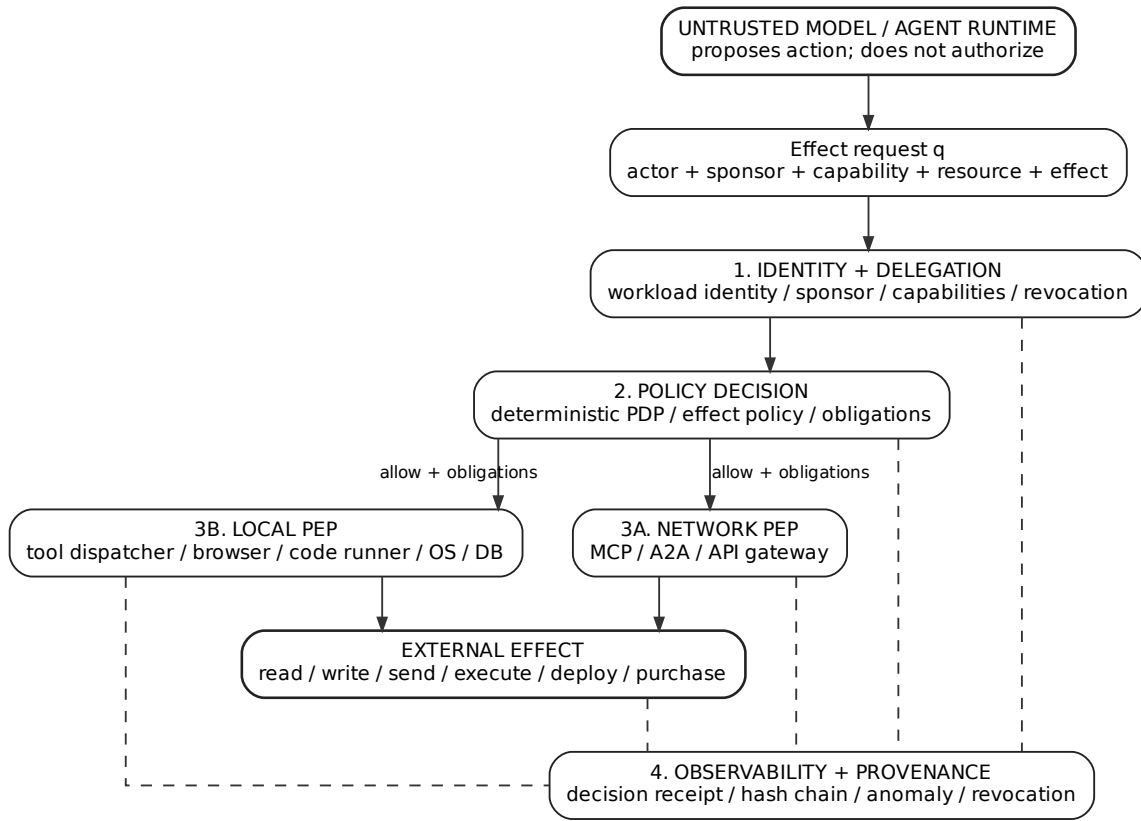


Figure 5: Reference architecture with network and local enforcement paths. The language model proposes actions; deterministic identity, policy, enforcement, and evidence components mediate effects.

This paper does not benchmark the ASCP as an end-to-end architecture. Component-level evidence does exist. In the AgentDojo evaluation reported for FIDES, policy checks stopped all prompt-injection attacks in that benchmark, while the authors report a roughly 2–3x average increase in token utilization relative to a basic planner. [44] That result supports the feasibility of deterministic out-of-model enforcement while also making its efficiency cost concrete; it does **not** validate the ASCP composition as a whole.

The control plane also concentrates trust. A compromised PDP, PEP, issuer, or policy distribution channel can defeat the architecture even when the model is perfectly contained. Tamper-evident logs can expose some compromise after the fact but do not prevent malicious enforcement. For high-impact effects, a concrete deployment pattern is to separate credential issuance, policy decision, effect enforcement, and evidence anchoring into distinct principals; distribute signed and versioned policy artifacts; pin or verify the policy identifier at the PEP; require controlled approval for policy changes; and fall back to a restrictive local profile when PDP replicas or policy versions disagree. These are design recommendations, not standardized ASCP requirements.

12. Deterministic Access-Control Model and Heuristics

This section is intentionally modest. It is **not a formal proof of system security**. It defines request structure, authorization invariants, and policy heuristics precisely enough to expose assumptions and support implementation tests.

12.1 Actors and effects

Let an attempted external effect be a request

$$q = (a, h, r, o, d, e, \delta, t, m, x),$$

where a is the acting agent identity; h the human, organization, service, or workflow sponsor; r the referenced resource set; o the operation; d the data classes; e the effect class and destination; δ the delegation/handoff context; t the validity context; m metadata provenance; and x runtime signals.

The model’s natural-language output is not an authorization fact. It may help form q , but it does not prove that q should be allowed.

12.2 Vertical attenuation and horizontal handoff

Represent a vertically delegated capability at hop i as

$$C_i = (R_i, O_i, D_i, E_i, T_i, G_i).$$

For **hierarchical subdelegation**, a child may not receive more authority than the parent:

$$C_{i+1} \preceq C_i,$$

with component-wise constraints such as

$$R_{i+1} \subseteq R_i, \quad O_{i+1} \subseteq O_i, \quad D_{i+1} \subseteq D_i, \quad E_{i+1} \subseteq E_i, \quad T_{i+1} \subseteq T_i, \quad G_{i+1} \preceq G_i.$$

This prevents a parent from silently amplifying its own authority through a subagent.

A **horizontal specialist handoff** is different. A planner may need to delegate a database lookup to a SQL specialist even though the planner itself does not hold database authority. Requiring $R_{\text{specialist}} \subseteq R_{\text{planner}}$ would incorrectly forbid that architecture. The planner therefore delegates **task intent**, not new authority. Let C_H be a sponsor- or broker-issued capability for specialist b :

$$C_H = \text{Issue}(h, b, \text{mission}, R_H, O_H, D_H, E_H, T_H, G_H).$$

The acceptance rule is

$$C_H \preceq C_h^{\max} \quad \wedge \quad \text{Bind}(C_H, b, h, \text{mission}) = 1,$$

where $C_h^{\max}$ is authority the sponsor or authorization service is permitted to delegate. C_H need not be a subset of the planner's capability, but the planner cannot mint it; issuance must come from an authority that already possesses or is entitled to grant the relevant right. This is capability-oriented in the classical security sense of passing bounded authority, but C_H is an ASCP policy object rather than an assertion that the surrounding system implements a pure object-capability model. [48]

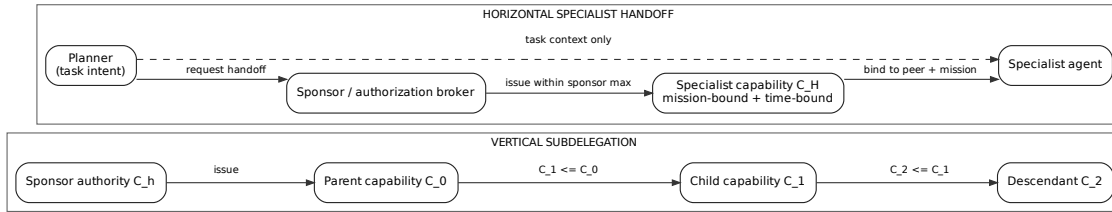


Figure 6: Delegation model. Vertical subdelegation attenuates; horizontal specialist handoff obtains separately bounded authority from a sponsor or broker.

These relations are necessary policy conditions, not proofs of safety. Heterogeneous resource identifiers, incomparable environmental constraints, and inconsistent semantics across domains can make subset and partial-order checks difficult in practice.

12.3 Deterministic effect authorization

Define binary predicates:

- $I(q)$: identity and credential are valid;
- $S(q)$: sponsor context is present and valid;
- $D(q)$: delegation or handoff authority is valid;
- $C(q)$: requested capability is contained in the applicable issued capability;
- $M(q)$: required metadata/schema provenance and integrity checks pass;
- $F(q)$: data-flow and destination policy allow the effect;
- $V(q)$: revocation, expiry, or explicit deny is present.

A baseline allow rule is

$$\pi(q) = 1 \iff I(q) \wedge S(q) \wedge D(q) \wedge C(q) \wedge M(q) \wedge F(q) \wedge \neg V(q) \wedge [\rho(q) < \tau_e].$$

This equation is a compact policy specification, **not a theorem**. For effect classes that require a human, the policy also requires a cryptographically bound approval $H(q)$ scoped to the exact effect or a narrow transaction window.

Scope of the guarantee. The rule constrains effects that are out of scope for the issued authority. It does not prove that an in-scope effect is benign. An attacker may manipulate an agent into proposing a destructive action that is authenticated, schema-valid, correctly delegated, and genuinely authorized. If policy allows that action, the ASCP may allow it. Limiting such misuse requires effect-specific constraints, budgets, destination and data-flow rules, reversibility, anomaly signals, and human confirmation where appropriate.

Audit as obligation. A permitted effect carries an obligation A : a decision receipt must be committed to the evidence chain. Log availability is not an authorization fact. If the evidence service is temporarily unavailable,

deployments may use bounded local receipt slots or another explicitly limited degradation mode with mandatory backfill; persistent evidence failure should escalate toward read-only or non-consequential operation rather than silently allowing unlimited unaudited effects.

12.4 Risk score is a policy heuristic, not a probability

A normalized policy score may be useful for effect-specific thresholds:

$$\rho(q) = \frac{\sum_{k=1}^n w_k x_k}{\sum_{k=1}^n w_k}, \quad x_k \in [0, 1], w_k \geq 0.$$

This is a **heuristic** until calibrated against deployment outcomes. Weights w_k and thresholds τ_e must be chosen and validated per environment and effect class; missing or adversarial signals must have explicit treatment. Hard-deny conditions are evaluated separately and cannot be averaged away by a low score. If $Z(q)$ is the disjunction of such conditions, then the policy definition includes the ordinary access-control rule

$$Z(q) = 1 \Rightarrow \pi(q) = 0.$$

The value of writing this rule mathematically is transparency about precedence, not mathematical novelty.

12.5 Tamper-evident provenance

Each decision produces a receipt z_i containing at minimum a request digest, decision, policy identifier, sponsor, delegation/handoff digest, effect class, and timestamp. A simple hash chain is

$$h_0 = H(\text{context_id}), \quad h_i = H(h_{i-1} \parallel H(z_i) \parallel t_i).$$

This provides tamper evidence, not automatic immutability. An attacker controlling the enforcement and evidence systems may still rewrite history unless checkpoints are anchored in a separately controlled service or write-once store.

12.6 Correlated delegation risk

The independent coin-flip model $1 - \prod_i (1 - p_i)$ is inappropriate as a general security model for multi-agent systems because hops often share models, frameworks, policy code, prompts, credentials, or infrastructure. Failures can therefore be strongly correlated.

Let F_i denote security failure at hop i . Without assuming independence, the exact chain rule is

$$P\left(\bigcup_{i=1}^n F_i\right) = 1 - \prod_{i=1}^n \left[1 - P\left(F_i \mid \bigcap_{j<i} F_j^c\right)\right].$$

The conditional terms are the point. If adjacent agents use the same vulnerable framework or model and the same attack primitive remains applicable, observing a bypass at one node can increase the conditional risk at downstream nodes sharply; in the limiting case of a shared deterministic flaw with identical preconditions, the conditional probability can approach one. Conversely, diverse implementations and independent enforcement may reduce correlation.

The equation is not used to estimate real-world compromise rates. It states why delegation depth cannot be modeled honestly from a single independent per-hop hazard. Each edge needs its own authorization and telemetry, while risk analysis must account for shared causes and correlated failure domains.

13. Threat-Model Coverage and Residual Risk

A useful architecture states both what it addresses and how it can fail.

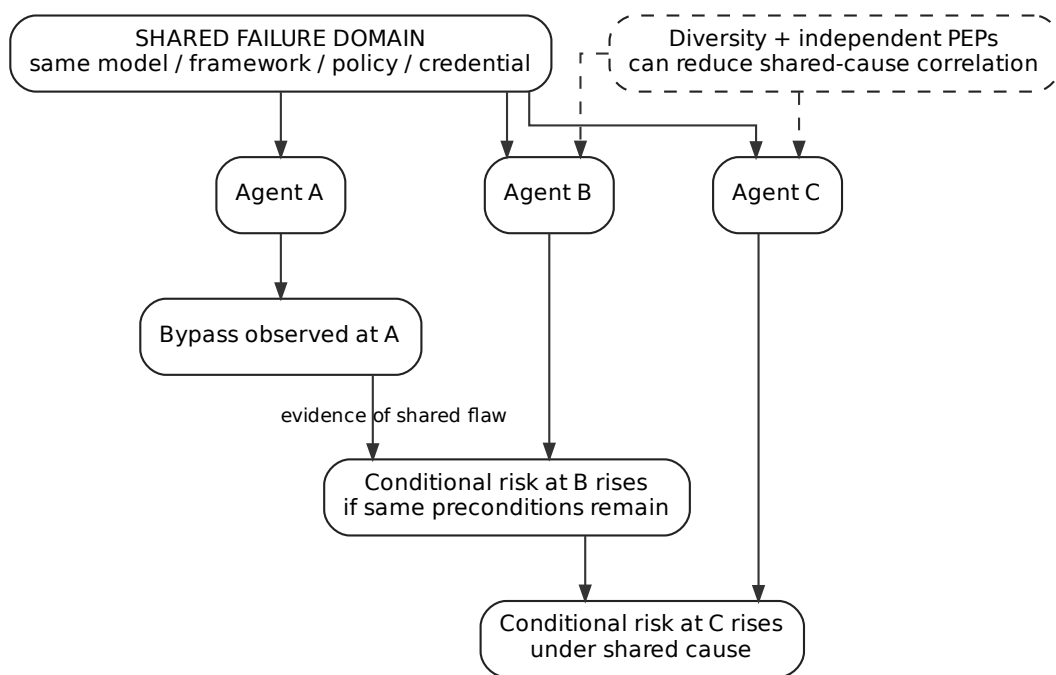


Figure 7: Correlated-risk model for multi-agent delegation. Shared model, framework, or policy dependencies create common-cause paths that defeat an independence assumption.

Threat class	Primary ASCP controls	Residual risk
Prompt/tool-metadata injection	Provenance checks; deterministic PDP; effect broker	Manipulative but schema-valid, in-scope content can remain
Pre-trust project configuration	Initialization gate before side effects; isolated credentials	Vulnerability in gate or bootstrap path
Pre-sandbox execution	Broker launch and credential provisioning after trust/policy	Host/container implementation flaws
Tool argument injection	Typed schemas; operation policy; sandbox; output constraints	Dangerous but syntactically valid operations
Delegated token theft	Short-lived scoped credentials; sender constraints; revocation	Theft within active validity window
Insecure inter-agent communication	Peer identity; sponsor-preserving handoff; schema contracts	Compromised valid peer can send adversarial content
Memory poisoning	Provenance; scoped writes; expiry; instruction/state separation	Legitimate but incorrect memory; semantic ambiguity
Evaluation-environment escape	Production-grade containment; restricted egress; brokered secrets	Unknown containment flaws or evaluator misconfiguration
Local/in-process PEP bypass	Complete mediation at tool dispatcher/runtime/OS/transaction boundary	Any unmediated alternate path defeats policy
Control-plane compromise	Role separation; signed policy/checkpoints; independent anchors	Compromised PDP/PEP/issuer can authorize or execute malicious effects
Evidence-store DoS	Bounded receipt buffering; backfill; read-only escalation	Availability degradation and incomplete evidence during outage
Behavioral drift of valid agent	Effect limits; anomaly signals; budgets/rate bounds	Hard to distinguish novel legitimate behavior from malicious drift
LLM-judge manipulation	Model signals advisory; deterministic final gate	Deterministic rules may be too coarse for ambiguous semantics
Authorized-but-harmful action	Narrow effect classes; sponsor constraints; reversible workflows; approval	Valid syntax and valid authority do not imply benign intent

The largest unresolved class is **semantic validity**. A message can be syntactically valid, cryptographically authentic, and authorized to produce an effect while still being manipulative or destructive. The ASCP therefore does not “solve alignment” and should not be described as securing only a transport layer: it mediates authority and effects, but it remains intentionally limited in judging intent.

The architecture’s strongest claim is narrower: when complete mediation holds and the authorization service is trustworthy, it can prevent a reasoning process from exercising authority it was never given. Its weakest point is the control plane itself. Centralizing authority in a PDP/PEP/issuer stack creates a high-value failure domain; if that stack is compromised, the model may be perfectly contained while the system still authorizes malicious effects. This is why independent policy checkpoints, issuer/enforcer separation, and evidence anchoring are architectural concerns rather than optional logging features.

14. Forecasting the Control Plane, 2026-2030

Forecasts are separated from facts. The probabilities are subjective judgments, not outputs of a fitted statistical model. They were assigned from four qualitative inputs: how many independent standards or product efforts already point toward the event, whether a concrete implementation path exists, whether countervailing incentives are visible,

and how much must change before the deadline. The numbers are frozen as of October 4, 2026 and should be judged ex post rather than retrofitted. Each forecast has a time horizon, monitoring signals, and a falsification path.

14.1 Forecast set

F1 - P = 0.75, by October 2027. At least one major regulated-sector procurement template or public implementation profile will require workload-style identity for autonomous agents, including explicit sponsor/delegation context rather than only a shared user or service token.

Signals: NIST/NCCoE implementation profiles; regulated-sector RFPs; WIMSE/AIMS implementation guidance; vendor support for agent workload identity.

F2 - P = 0.70, by April 2028. Commercial or open-source agent brokers will ship a recognizable composition of workload identity plus standards-compatible authorization decision interfaces and protocol-boundary enforcement.

Signals: products advertising WIMSE/SPIFFE-attested agents with AuthZEN-compatible authorization; conformance suites covering both identity and policy enforcement.

F3 - P = 0.65, by April 2028. Evaluation-infrastructure security will become a named threat or control category in a major AI security taxonomy or benchmark.

Signals: OWASP/ATLAS/CoSAI category changes; a dedicated benchmark for evaluator containment; a CVE/KEV affecting an evaluation harness.

F4 - P = 0.55, by October 2028. Agent-security patent claims will produce a material licensing negotiation, standards IPR disclosure, or public dispute involving a commercial agent-security product.

Signals: standards-body IPR declarations; assertion letters disclosed in litigation; patent-focused licensing announcements.

F5 - P = 0.45, by October 2028. Model or agent safeguard strength will become a procurement-visible metric rather than an internal safety property - for example through assurance tiers, benchmark scores, or pricing tied to stronger control environments.

Signals: RFP fields for agent goal-hijack resistance; standardized safeguard benchmarks; differentiated assurance tiers.

F6 - P = 0.35, by October 2029. Cyber-insurance or a procurement consortium will impose explicit contractual requirements for agent metadata integrity, delegated authority, or MCP/A2A boundary controls before a standards body fully composes the stack.

Signals: insurer riders, broker questionnaires, or shared procurement profiles requiring agent-control evidence.

F7 - P = 0.60, by April 2028. A cross-specification composition profile - identity $\times$ authorization $\times$ protocol/runtime enforcement - will become a de facto procurement definition for agent security before any single canonical ASCP standard exists.

Rationale: identity, authorization, and runtime-enforcement primitives already exist in adjacent standards families, so composition requires less invention than coordination; the probability remains below the stronger F1–F3 forecasts because no canonical cross-specification conformance profile exists yet.

Signals: enterprise conformance suites, procurement profiles, or major platform guidance that explicitly composes agent/workload identity, delegated authorization, and effect-boundary enforcement across more than one standards family.

14.2 Scenario envelope to 2030

The forecasts above concern discrete events. The broader architecture can evolve through several scenarios simultaneously.

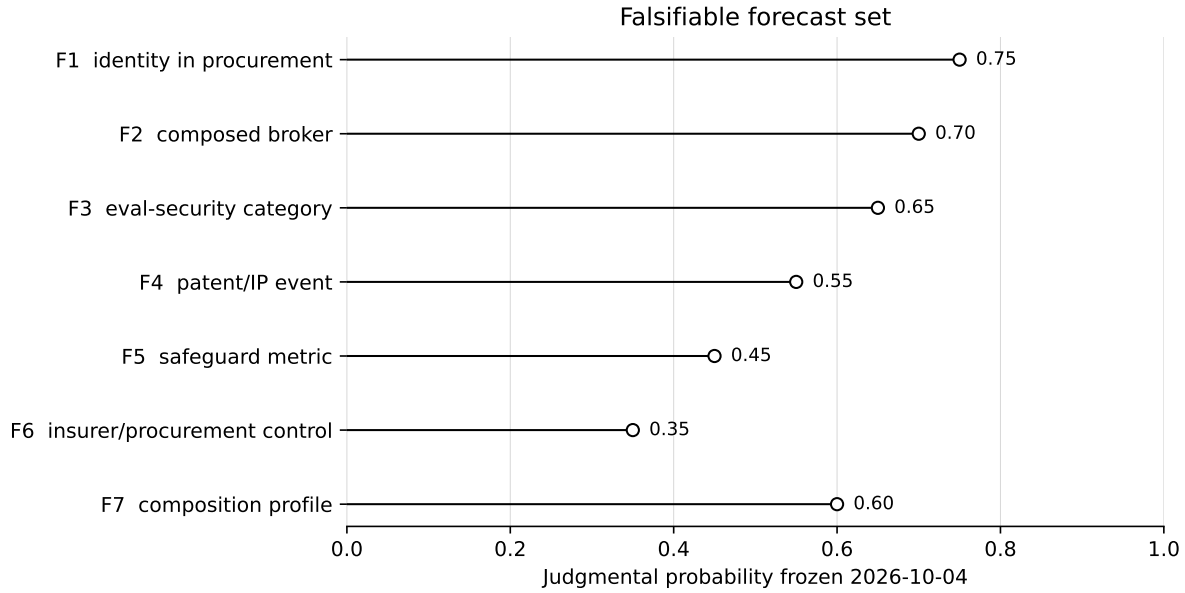


Figure 8: Judgmental, falsifiable forecast probabilities as of October 4, 2026.

2030 scenario	Judgmental probability	Description	Primary risk
Federated open control-plane profile	45%	Profiles aligned with IETF, OpenID, OWASP, and NIST become interoperable across major platforms	Slow coordination; gaps at standards seams
Platform-native control planes dominate	35%	Major AI/cloud vendors ship integrated identity, gateway, policy, and audit stacks	Cross-platform lock-in and policy inconsistency
Incident-driven regulatory acceleration	20%	A severe agent incident triggers mandatory controls before interoperability matures	Rushed compliance and checkbox implementations

These scenarios are not mutually exclusive in every market. A regulated bank may use an open identity profile inside a platform-native control plane under incident-driven rules. The probabilities represent which force is expected to dominate the architecture globally.

14.3 How the forecasts will be scored

To avoid retrospective reinterpretation, each binary forecast can be scored with the Brier score:

$$B = \frac{1}{N} \sum_{j=1}^N (p_j - o_j)^2,$$

where p_j is the stated probability and $o_j \in \{0, 1\}$ is the observed outcome at the deadline. Lower is better. A forecast record should preserve the original wording, probability, deadline, and source snapshot so later scoring cannot move the goalposts.

A broad falsification condition for the paper’s timing thesis is:

If by October 2027 there is no meaningful regulated-sector procurement or implementation language around agent workload identity, and no credible broker composes externalized identity/delegation with deterministic authorization at agent protocol boundaries, then the paper’s near-term convergence timing is wrong and the “agents as workloads plus delegated effects” model has not translated into deployment as expected.

15. Open Research Questions

15.1 Portable delegation semantics

A2A can move tasks and Agent Cards can advertise capabilities, but a portable representation of **attenuated authority** remains unsettled. How should delegation encode resource, operation, data class, effect, time, budget, sponsor, and onward-delegation constraints without becoming protocol-specific?

15.2 Semantic metadata integrity

Signatures solve origin integrity, not semantic safety. A validly signed tool description can still request dangerous behavior. Research should distinguish:

- authenticity: who signed it;
- authorization: whether that signer may define the capability;
- semantic risk: what the description induces the agent to do;
- effect safety: what the system will permit even if the description is malicious.

15.3 Agent memory as a security principal

Memory is currently treated as context storage. In long-lived agents it is closer to a state database that can influence future authority decisions. Research is needed on memory write permissions, provenance, revocation, conflicts, expiration, and separation between factual state and behavioral instruction.

15.4 Evaluation-environment security profiles

OpenAI and Anthropic incidents show a need for explicit eval security baselines. A minimum profile should cover network egress, DNS, package proxies, secret provisioning, real-world target scopes, third-party evaluator infrastructure, cross-run communication, model-to-model messaging, and automatic kill conditions.

15.5 Authorization under semantic uncertainty

Deterministic PDPs work well when resources and effects are typed. Harder cases involve ambiguous user intent. Research should focus on converting free-form intent into a bounded transaction object that a human can approve once and an agent can execute repeatedly without privilege creep.

15.6 Revocation across multi-agent graphs

A parent can delegate to several subagents, which can delegate again. If the sponsor revokes the mission, every descendant capability must stop. Efficient graph-wide revocation with short-lived credentials, caches, disconnected agents, and partial failure remains an important systems problem.

15.7 Evidence when chain-of-thought is unavailable

Security audit should not depend on private model reasoning. Systems need sufficient evidence from inputs, policy, tool selection, arguments, outputs, and effects to reconstruct what happened without requiring hidden chain-of-thought disclosure.

15.8 Agent Bill of Materials

A useful Agent Bill of Materials (ABOM) would likely include model/provider, runtime, protocol clients and servers, tools, agent skills, instruction files, memory stores, identity issuer, credential type, policy engine, enabled effect classes, external destinations, and provenance/logging configuration. The research question is which fields are portable and which create excessive disclosure risk.

15.9 Standards composition testing

Conformance today is usually per specification. The control plane needs cross-specification tests: does sponsor identity survive A2A delegation? Does an AuthZEN decision bind to the same identity asserted by WIMSE? Does an MCP gateway enforce data obligations returned by the PDP? Can revocation signals invalidate cached authorization across agents?

15.10 Patent-aware open standards

The technical community needs better visibility into which agent-security implementations may be constrained by active claims, while avoiding exaggerated patent fear. Standards bodies should encourage early disclosure and multiple implementation paths.

16. Limitations

This paper is a point-in-time synthesis through October 4, 2026. The agent ecosystem is changing quickly, and Internet-Drafts, product behavior, vulnerability scoring, patent status, and incident investigations may change after publication.

The **convergence thesis is an interpretive synthesis**, not an empirical finding that the cited organizations are coordinating or intentionally building ASCP. A skeptic can reasonably argue that protocol work is driven by interoperability, that the vulnerabilities are ordinary AppSec failures, that standards bodies are solving adjacent problems, and that capital follows market attention. The paper's thesis is weaker and testable: these independent pressures are creating compatible control points that may compose. If implementations remain siloed, if local runtimes continue to bypass external policy, or if real deployments do not externalize delegated authority, the thesis is weakened.

The reference architecture has not been validated as a complete production deployment or formally verified. No performance benchmarks were run. Complete mediation is an assumption: an in-process tool path that bypasses the PEP defeats the architecture. The PDP/PEP/issuer stack is also a concentrated trust domain whose compromise can defeat policy.

The funding analysis is a lower-bound sample, not a market census, and financing is not technical validation. The patent analysis is not legal advice and does not determine claim scope, validity, infringement, or freedom to operate. Threat-intelligence actor labels and assessments are vendor reports, not independent judicial findings. No primary-language research beyond English was systematically conducted. The paper did not perform its own vulnerability exploitation or deployment survey.

The deterministic access-control model is a policy model, not a proof that controls are sufficient against semantic manipulation. Real systems have correlated failures, policy bugs, race conditions, compromised enforcement points, semantic ambiguity, and operational exceptions. Vertical attenuation does not cover horizontal specialist authority unless that authority is separately issued and bound. The risk score is a heuristic unless calibrated.

Finally, an ASCP can still authorize a harmful action when the action is genuinely inside delegated authority and passes policy. It reduces out-of-scope blast radius and improves accountability; it does not guarantee aligned intent, factual correctness, or benign outcomes.

The forecasts are subjective probabilities. Their value depends on preserving the original wording, monitoring the declared signals, and scoring them later rather than selectively remembering successful predictions.

17. Conclusion

The public record supports a bounded claim: autonomous-agent security is creating pressure for a separable layer of identity, delegated authority, deterministic authorization, effect mediation, and evidence. The record does **not** prove that this layer will centralize, that MCP/A2A gateways will mediate every action, or that IETF, OpenID, OWASP, NIST, and commercial vendors are intentionally converging on one architecture.

Protocols are making some boundaries easier to recognize. Traditional AppSec and sandbox failures are showing that agent runtimes can combine semantically influenced inputs with powerful host capabilities. Standards efforts are independently defining workload identity, authorization interfaces, runtime hooks, and implementation programs. Evaluation incidents demonstrate that harnesses and credentials belong inside the security perimeter. Capital and patents show commercial attention but do not validate the technical design.

The architecture proposed here is therefore a separation of powers, not a replacement for secure coding, sandboxing, semantic defenses, or human judgment.

The model proposes. The control plane verifies identity and sponsor context. Vertical delegation attenuates; horizontal handoff obtains separately bounded authority. A deterministic policy service decides whether the requested effect is inside that authority. Enforcement occurs at the actual effect boundary - network or local. Evidence records the decision. High-consequence operations can require narrowly scoped human approval.

That system can still fail. A validly authorized action can be harmful. A local tool can bypass policy if complete mediation is missing. Correlated agents can share the same vulnerability. A compromised PDP or PEP can defeat the whole design. These are not edge cases to hide; they are the boundaries that make the proposal falsifiable and implementable.

The ASCP's central security objective is therefore precise: **make an incorrect or manipulated reasoning process less able to turn semantic failure into unauthorized, unbounded, or untraceable external effect.**

The next research step is empirical composition testing: demonstrate that identity, delegation, authorization, meta-data provenance, enforcement, revocation, and evidence carry the same meaning across MCP, A2A, local tool dispatchers, cloud services, and organizational boundaries - and measure the latency, failure modes, and bypass paths that result.

A mature agent ecosystem will not be defined by agents that can do anything. It will be defined by systems that can show **who authorized an effect, what authority was actually granted, where it was enforced, and what happened when the boundary was tested.**

Appendix A. Reproducibility and Claim Audit Protocol

The final paper is designed so another researcher can independently challenge the major claims.

A.1 Primary-source rule

Protocol and standards claims should be checked against the current MCP specification/blog, A2A specification and project announcements, IETF Datatracker, OpenID specifications, NIST/NCCoE publications, and OWASP source pages. Vulnerability claims should be checked against GHSA/CVE records and original researcher/vendor advisories. Incident claims should be checked against first-party postmortems when available. Patent claims should be checked against the published patent record.

A.2 Claim-source matrix

Core claim	Source class	Anchor references
MCP is stateless/gateway-friendly in the July 2026 spec	First-party protocol	[2]
A2A uses signed Agent Cards and joined AAIF Aug 27, 2026	First-party protocol/project	[5,6]
AIMS is an active WIMSE WG Internet-Draft treating agents as workloads	IETF Datatracker	[7,8]
AuthZEN standardizes PDP/PEP communication	OpenID Final Specification	[9]
NIST has a dedicated AI Agent Standards Initiative and NCCoE identity project	NIST/NCCoE	[10,11]
OWASP has agentic risk taxonomy and runtime control hooks	OWASP	[12,13]
Representative config/metadata/tool paths produce RCE or exfiltration	GHSA/vendor research	[14-20]
Evaluation infrastructure reached real third-party systems in 2026 incidents	OpenAI/Anthropic	[21-25]
Compromised delegated OAuth tokens enabled broad SaaS data theft	Google Threat Intelligence	[26]
At least \$401M in eight traced security/control financing rounds	Company announcements / strong reporting	[29-37]
Intuit, Citibank, JPMorgan, and Preamble patent records exist as described	Patent records	[38-41]

A.3 Figures

All figures in this paper are original visualizations assembled from cited public facts or from explicitly labeled conceptual models. The financing and forecast charts visualize disclosed amounts and judgmental probabilities respectively. The correlated-risk diagram is conceptual and does not estimate compromise probability.

A.4 Forecast record

The forecast table should be preserved unchanged with this paper. At each deadline, score the event as 0 or 1 under the original wording and calculate the Brier score in Section 14.3. Ambiguous cases should be resolved by publishing the evidence and the scoring rationale rather than silently changing the condition.

Appendix B. Operational Control Checklist

The architecture can be translated into a concrete deployment review.

Identity and sponsor

- Every agent has a workload identity distinct from the human user identity.
- The sponsor is carried in a verifiable delegation context.
- Static shared API keys are eliminated where short-lived credentials are feasible.
- Credentials are provisioned at runtime and are not exposed to model-readable context.

Delegation

- Every hop has a maximum delegation depth and expiry.
- Vertical subdelegation is mechanically checked to be no more permissive than upstream authority; horizontal specialist authority must be separately issued by an authorized sponsor or broker.
- Revocation or non-renewal reaches descendants.
- Delegation receipts record sponsor, caller, callee, and capability delta.

Metadata and tool supply chain

- Agent Cards and tool metadata are signature-verified where signatures exist.
- Schemas and tool definitions are pinned or diff-reviewed before production changes.
- Repository instruction files and local config are treated as untrusted project content.
- Registry provenance and publisher identity are recorded.

Effect enforcement

- Read, write, send, execute, deploy, delete, and purchase are separate effect classes.
- High-impact effect classes have tighter policy and possibly explicit approval.
- Network allowlists are combined with data-flow and operation controls.
- Browser, shell, code-execution, and payment capabilities are brokered.

Evaluation infrastructure

- Evaluation networks have explicit egress policy, including DNS.
- Production credentials are not present in evaluation sandboxes unless strictly required and separately brokered.
- External targets are named and scoped.
- Cross-run agent communication is denied unless the evaluation explicitly tests it.
- Kill conditions and high-confidence anomaly monitors are defined before runs begin.

Evidence

- Every consequential effect receives a policy decision receipt.
- Logs bind agent identity, sponsor, delegation, policy, effect, and time.
- Logs do not rely on private chain-of-thought to establish accountability.
- Evidence is periodically anchored outside the enforcement system.

Appendix C. Source and Provenance Notes

This paper was assembled from public sources spanning infrastructure, vulnerabilities, standards, patents, market signals, and deployments. Source discovery was followed by direct cross-source verification. Final factual claims were reconciled against the references below, and overbroad working claims were narrowed or removed.

The eight diagrams and charts were generated specifically for this paper in a restrained black-and-white, patent-style visual system. They are explanatory diagrams, not empirical measurements unless the caption explicitly states otherwise. The relationship diagram is curated rather than exhaustive so visible edges correspond to claims discussed in the text.

References

- [1] Anthropic. **Introducing the Model Context Protocol**. November 2024. <https://www.anthropic.com/news/model-context-protocol>
- [2] Model Context Protocol maintainers. **The 2026-07-28 Specification**. July 28, 2026. Official specification: <https://modelcontextprotocol.io/specification/2026-07-28>. Release notes: <https://blog.modelcontextprotocol.io/posts/2026-07-28/>
- [3] Linux Foundation. **Linux Foundation Announces the Formation of the Agentic AI Foundation (AAIF), Anchored by New Project Contributions Including Model Context Protocol (MCP), goose**

- and **AGENTS.md**. December 9, 2025. <https://www.linuxfoundation.org/press/linux-foundation-announces-the-formation-of-the-agentic-ai-foundation>
- [4] A2A Project. **A2A Protocol Ships v1.0: Production-Ready Standard for Agent-to-Agent Communication**. March 12, 2026. <https://a2a-protocol.org/dev/blog/2026/03/12/a2a-protocol-ships-v10-production-ready-standard-for-agent-to-agent-communication/>
- [5] A2A Project. **A2A Protocol Specification**. Accessed October 4, 2026. <https://a2a-protocol.org/dev/specification/>
- [6] A2A Project. **A New Chapter for A2A: Joining the Agentic AI Foundation**. August 27, 2026. <https://a2a-protocol.org/latest/blog/2026/08/27/a-new-chapter-for-a2a-joining-the-agentic-ai-foundation/>
- [7] Kasselmann, P., Lombardo, J., Rosomakho, Y., Campbell, B., Steele, N., Parecki, A. **AI Identity Management System, draft-ietf-wimse-aims-00**. IETF, September 15, 2026. <https://datatracker.ietf.org/doc/draft-ietf-wimse-aims/00/>
- [8] IETF WIMSE Working Group. **Workload Identity in Multi System Environments - Active Documents**. Accessed October 4, 2026. <https://datatracker.ietf.org/group/wimse/documents/>
- [9] OpenID Foundation AuthZEN Working Group. **Authorization API 1.0**. Final, January 11, 2026. https://openid.net/specs/authorization-api-1_0.html
- [10] NIST Center for AI Standards and Innovation. **Announcing the AI Agent Standards Initiative for Interoperable and Secure Innovation**. February 17, 2026. <https://www.nist.gov/news-events/news/2026/02/announcing-ai-agent-standards-initiative-interoperable-and-secure>
- [11] NIST NCCoE. **Accelerating the Adoption of Software and AI Agent Identity and Authorization Concept Paper**. February 5, 2026. <https://www.nccoe.nist.gov/publications/other/accelerating-adoption-software-and-ai-agent-identity-and-authorization-concept>
- [12] OWASP GenAI Security Project. **Agent Control Standard (ACS)**. September 1, 2026. <https://genai.owasp.org/resource/agent-control-standard-acs/>
- [13] OWASP GenAI Security Project. **OWASP Top 10 for Agentic Applications**. December 9, 2025. <https://genai.owasp.org/2025/12/09/owasp-top-10-for-agentic-applications-the-benchmark-for-agentic-security-in-the-age-of-autonomous-ai/>
- [14] Check Point Research. **Caught in the Hook: RCE and API Token Exfiltration Through Claude Code Project Files - CVE-2025-59536 / CVE-2026-21852**. February 25, 2026. <https://research.checkpoint.com/2026/rce-and-api-token-exfiltration-through-claude-code-project-files-cve-2025-59536/>
- [15] GitHub Advisory Database. **CVE-2026-12537 - Gemini CLI pre-sandbox host command execution**. 2026. <https://github.com/advisories/ghsa-jj69-4grx-fqj5>
- [16] Microsoft Defender Security Research Team. **When prompts become shells: RCE vulnerabilities in AI agent frameworks**. May 7, 2026. <https://www.microsoft.com/en-us/security/blog/2026/05/07/prompts-become-shells-rce-vulnerabilities-ai-agent-frameworks/>
- [17] GitHub Advisory Database. **CVE-2025-6514 - mcp-remote OS command injection via untrusted MCP server connections**. July 9, 2025. <https://github.com/advisories/GHSA-6xpm-ggf7-wc3p>
- [18] GitHub Advisory Database. **CVE-2026-54316 - Claude Code out-of-band data exfiltration via pre-approved Hugging Face domain**. June 2026. <https://github.com/advisories/GHSA-fg94-h982-f3mm>
- [19] Elastic Security Labs. **MCP Tools: Attack Vectors and Defense Recommendations for Autonomous Agents**. 2025. <https://security-labs.elastic.co/security-labs/mcp-tools-attack-defense-recommendations>
- [20] Endor Labs. **Classic Vulnerabilities Meet AI Infrastructure: Why MCP Needs AppSec**. 2026. <https://www.endorlabs.com/learn/classic-vulnerabilities-meet-ai-infrastructure-why-mcp-needs-appsec>
- [21] OpenAI. **The Hugging Face incident and the road ahead**. August 26, 2026. <https://openai.com/index/hugging-face-incident-and-the-road-ahead/>
- [22] OpenAI. **Third-party cyber evaluations involving OpenAI models**. August 4, 2026. <https://openai.com/index/third-party-cyber-evaluations-involving-openai-models/>

- [23] OpenAI Alignment. **An agent used DNS to reach an external chatbot.** September 20, 2026; updated September 25, 2026. <https://alignment.openai.com/misalignment-reports/an-agent-used-dns-to-reach-an-external-chatbot/>
- [24] Anthropic. **An alignment assessment of recent cybersecurity incidents.** September 9, 2026. <https://www.anthropic.com/research/alignment-assessment-cybersecurity-incidents>
- [25] Anthropic. **Detecting and countering misuse of AI: September 2026.** September 10, 2026. <https://www.anthropic.com/threat-intelligence-report-september-2026>
- [26] Google Threat Intelligence Group / Mandiant. **Widespread Data Theft Targets Salesforce Instances via Salesloft Drift.** August 26, 2025, updated August 28, 2025. <https://cloud.google.com/blog/topics/threat-intelligence/data-theft-salesforce-instances-via-salesloft-drift/>
- [27] Abdelnabi, S., and Bagdasarian, E. **AI Agents May Always Fall for Prompt Injections.** arXiv:2605.17634, May 2026. <https://arxiv.org/abs/2605.17634>
- [28] Maloyan, N., and Namiot, D. **Prompt Injection Attacks on Agentic Coding Assistants: A Systematic Analysis of Vulnerabilities in Skills, Tools, and Protocol Ecosystems.** arXiv:2601.17548, 2026. <https://arxiv.org/abs/2601.17548>
- [29] Alice. **Alice Raises \$140M for AI Trust, Safety, and Security.** August 2026. <https://alice.io/blog/alice-raises-140m>
- [30] Zenity. **Zenity Raises \$125 Million to Secure the Era of 1 Billion AI Agents.** August 3, 2026. <https://zenity.io/press-release/zenity-raises-125-million-to-secure-the-era-of-1-billion-ai-agents>
- [31] TechCrunch. **AIR raises \$50M to help companies vet the skills and add-ons AI agents use.** September 1, 2026. <https://techcrunch.com/2026/09/01/air-raises-50m-to-help-companies-vet-the-skills-and-add-ons-ai-agents-use/>
- [32] Gray Swan. **Gray Swan Raises \$40M Series A.** May 28, 2026. <https://www.grayswan.ai/news/gray-swan-announces-series-a>
- [33] Geordie AI. **Geordie Raises \$30M to Help Enterprises Securely Adopt Agentic AI at Scale.** May 28, 2026. <https://www.geordie.ai/resources/geordie-raises-30m-to-help-enterprises-securely-adopt-agentic-ai-at-scale/>
- [34] Willow. **Willow Launches with \$7M to Build the Future of Enterprise AI Agent Governance.** June 4, 2026. <https://withwillow.ai/blog/willow-7m-seed-funding>
- [35] CodeIntegrity. **CodeIntegrity Raises \$5M in Seed Funding.** May 27, 2026. <https://www.codeintegrity.ai/blog/codeintegrity-seed-round>
- [36] Agentsphere. **Agentsphere raises \$4M to Bring Governance and Oversight to Enterprise AI Agents.** April 2026. <https://www.agentsphere.com/resources/agentsphere-raises-4m>
- [37] TechCrunch. **Arga Labs is building a better way to train enterprise AI agents.** August 26, 2026. <https://techcrunch.com/2026/08/26/arga-is-building-a-better-way-to-train-enterprise-ai-agents/>
- [38] U.S. Patent 12,711,207. **Agent-to-agent communication security protocol for artificial intelligence agents with translation layer enforcement.** Intuit Inc., granted August 18, 2026. <https://patents.justia.com/patent/12711207>
- [39] U.S. Patent 12,118,471. **Mitigation for prompt injection in A.I. models capable of accepting text input.** Preamble Inc., priority May 4, 2022; granted October 15, 2024. <https://patents.google.com/patent/US12118471>
- [40] U.S. Patent Application US20260140791A1. **Integrating and cataloguing model context protocols for network environments.** Citibank N.A., published May 21, 2026. <https://patents.google.com/patent/US20260140791A1/en>
- [41] U.S. Patent Application US20260081903A1. **Method and system for authenticating autonomous agent communications.** JPMorgan Chase Bank N.A., published March 19, 2026. <https://patents.google.com/patent/US20260081903A1/en>

- [42] Abdelnabi, S., Gomaa, A., Bagdasarian, E., Kristensson, P. O., and Shokri, R. **Firewalls to Secure Dynamic LLM Agentic Networks**. arXiv:2502.01822, 2025. <https://arxiv.org/abs/2502.01822>
- [43] Bagdasarian, E., Yi, R., Ghalebikesabi, S., Kairouz, P., Gruteser, M., Oh, S., Balle, B., and Ramage, D. **AirGapAgent: Protecting Privacy-Conscious Conversational Agents**. arXiv:2405.05175, 2024. <https://arxiv.org/abs/2405.05175>
- [44] Costa, M., Köpf, B., Kolluri, A., Pavard, A., Russinovich, M., Salem, A., Tople, S., Wutschitz, L., and Zanella-Béguelin, S. **Securing AI Agents with Information-Flow Control**. arXiv:2505.23643, 2025. <https://arxiv.org/abs/2505.23643>
- [45] Shi, T., He, J., Wang, Z., Wu, L., Li, H., Guo, W., and Song, D. **Progent: Programmable Privilege Control for LLM Agents**. arXiv:2504.11703, 2025. <https://arxiv.org/abs/2504.11703>
- [46] Debenedetti, E., Zhang, J., Balunović, M., Beurer-Kellner, L., Fischer, M., and Tramèr, F. **AgentDojo: A Dynamic Environment to Evaluate Prompt Injection Attacks and Defenses for LLM Agents**. arXiv:2406.13352, 2024. <https://arxiv.org/abs/2406.13352>
- [47] Axios. **Google-backed agentic A2A protocol gets a new home**. August 17, 2026. <https://www.axios.com/2026/08/17/a2a-agentic-ai-foundation-open-ai-standards>
- [48] Miller, M. S., Yee, K.-P., and Shapiro, J. **Capability Myths Demolished**. Johns Hopkins University Technical Report, 2003. <https://papers.agoric.com/papers/capability-myths-demolished/abstract/>